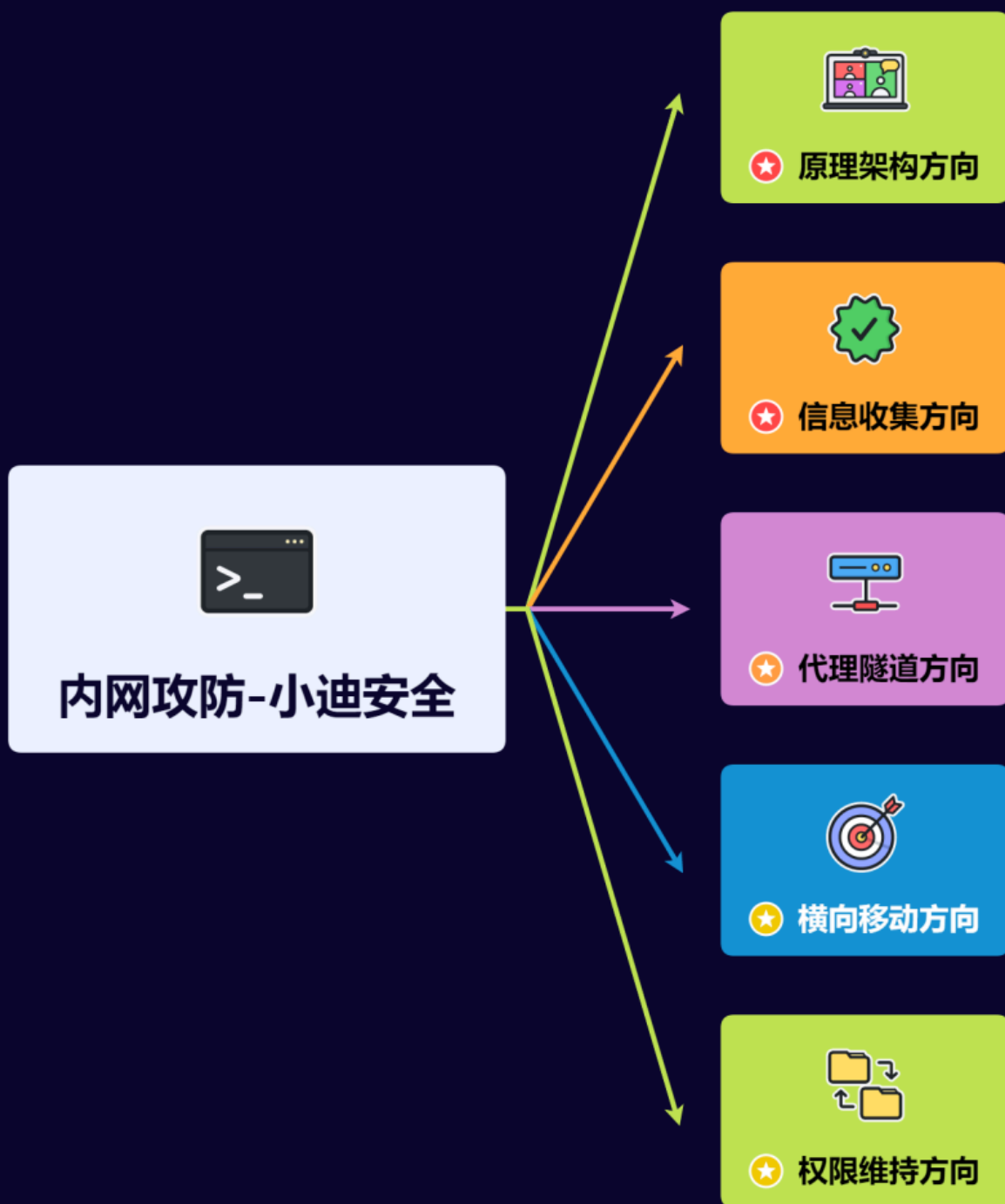


Day168 内网对抗-基石框架篇&单域架构&域内应用控制&成员组成&用户策略&信息收集&环境搭建



1.知识点

- 1、基石框架篇-单域架构-权限控制-用户和网络
- 2、基石框架篇-单域架构-环境搭建-准备和加入
- 3、基石框架篇-单域架构-信息收集-手工和工具

2.详细点



- 1 1、认知处于什么网络环境下
- 2 2、认知内网域分类及成员架构
- 3 3、认知信息收集有那些重要信息
- 4 4、认知代理隧道有那些方法技术
- 5 5、认知横向移动有那些方法技术
- 6 5、认知权限维持有那些方法技术

2.1 工作组



- 1 将不同的计算机按照功能分别列入不同的工作组。想要访问某个部门的资源，只要在“网络”里面双击该部门的工作组名。工作组就像一个可以自由进入和退出的社团，方便同组的计算机相互访问，工作组没有集中管理作用，工作组里的计算机都是相互对等的（即没有服务器和客户机之分）。对局域网中的计算机进行分类，使得网络更有序。计算机的管理依然是各自为政，所有计算机依然是对等的，松散会员制，可以随意加入和退出，且不同工作组之间的共享资源可以相互访问。

2.2 内网域



- 1 分类：单域、子域、父域、域树、域森林、DNS域名服务器
- 2 “域”是一个有安全边界的计算机组合（一个域中的用户无法访问另一个域中的资源），域内资源由一台域控制器（Domain Controller, DC）集中管理，用户名和密码是放在域控制器去验证的。
- 3 优点：通过组策略来统一管理。
- 4 单域：即只有一个域的网络环境，一般需要两台DC，一台DC，另一台备用DC（容灾）
- 5 父子域：类比公司总部和公司分部的关系，总部的域称为父域，各分部的域称为该域的子域。使用父子域的好处：
- 6
 - 减小了域之间信息交互的压力（域内信息交互不会压缩，域间信息交互可压缩）
 - 不同的子域可以指定特定的安全策略
- 8 父子域中域名使用一个.表示一个层次，类似于DNS域名表示方式，子域只能使用父域的名字作为域名后缀
- 9 域树：多个域通过建立信任关系组成的集合。若两个域之间需要相互访问，需要建立信任关系（Trust Relation），通过信任关系可以将父子域连接成树状结构
- 10 域森林：多个域树通过建立信任关系组成的集合。
- 11 域名服务器：实现域名到IP地址的转换。由于域中计算机使用DNS来定位DC、服务器和其他计算机的，所以域的名字就是DNS域的名字。
- 12 内网渗透中，大都是通过寻找DNS服务器来确定域控制器位置（因为DNS服务器和域控制器通常配置在一台机器上）

2.3 域内权限



- 1 • 域本地组：
 - 2 • 多域用户访问单域资源
- 3 • （访问同一个域），主要用于授予本域内资源的访问权限，可以从任何域中添加用户账号、通用组和全局组。域本地组无法嵌套在其他组中
- 4 • 全局组：
 - 5 • 单域用户访问多域资源
- 6 • （必须是同一个域中的用户），只能在创建该全局组的域中添加用户和全局组，但可以在域森林中的任何域内指派权限，也可以嵌套在其他组中
- 7 • 通用组：多域用户访问多域资源，成员信息不保存在域控制器中，而是保存在全局编录（GC）中，任何变化都会导致全林复制

2.4 域内组划分



- 1 域本地组：来自全林作用于本域
- 2 全局组：来自本域作用于全林
- 3 通用组：来自全林作用于全林
- 4 本地域组的权限
- 5 Administrators（管理员组） ----最重要的权限
- 6 Remote Desktop Users（远程登录组）
- 7 Print Operators（打印机操作员组）
- 8 Account Operators（帐号操作员组）
- 9 Server Operators（服务器操作员组）
- 10 Backup Operators（备份操作员组）
- 11 全局组、通用组的权限
- 12 Domain Admins（域管理员组） ----最最最重要的权限，一般来说域渗透是看重这个
- 13 Enterprise Admins（企业系统管理员组） ----最重要的权限，其次是去看重这个权限
- 14 Schema Admins（架构管理员组） ----最重要的权限
- 15 Domain Users（域用户组）

2.5 A-G-DL-P策略



- 1 A 代表用户账号（Account）。
- 2 G 代表全局组（Global Group）。
- 3 DL 代表域本地组（Domain Local Group）。
- 4 P 代表资源访问权限（Permission）。
- 5 A-G-DL-P策略是一种将用户账号添加到全局组中，然后将全局组添加到域本地组中，并为域本地组分配资源访问权限的策略。这种策略使得来自不同域的用户能够通过全局组和域本地组的组织方式，访问本地域中的资源。

2.6 域环境应用

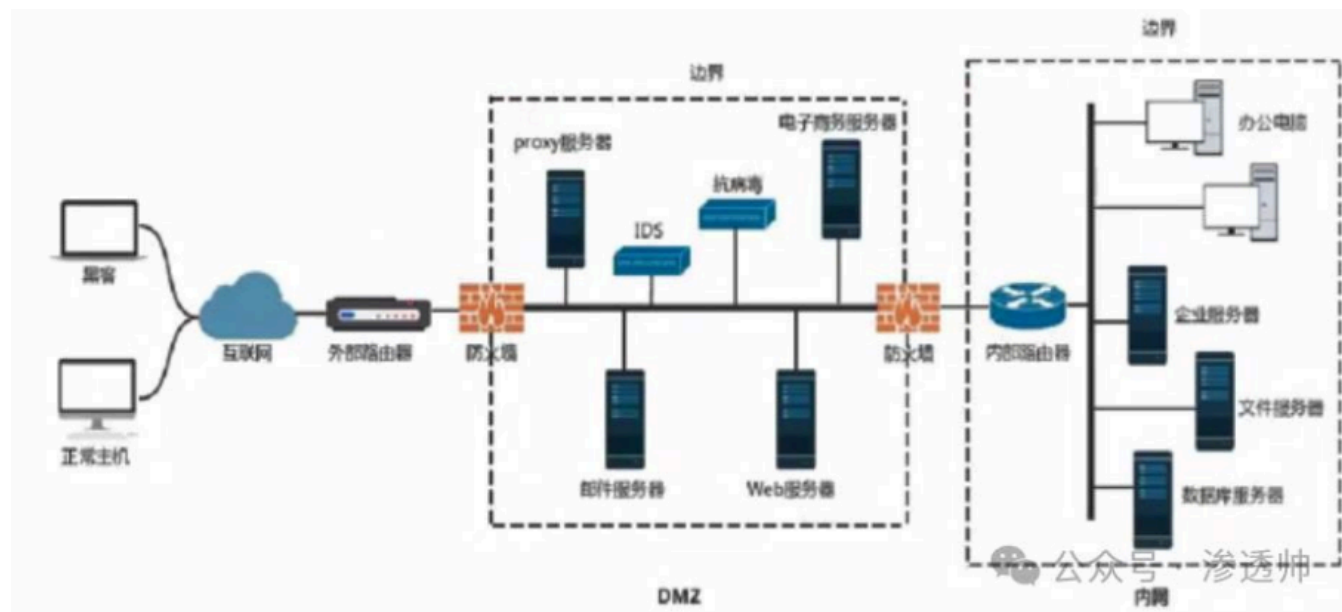


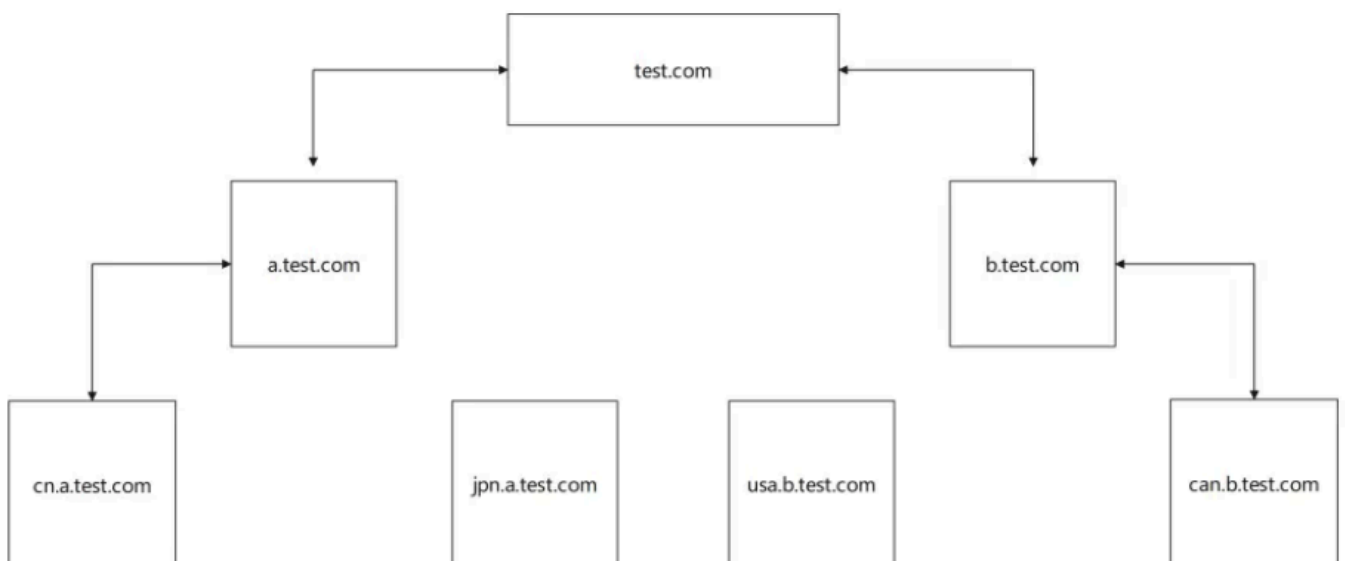
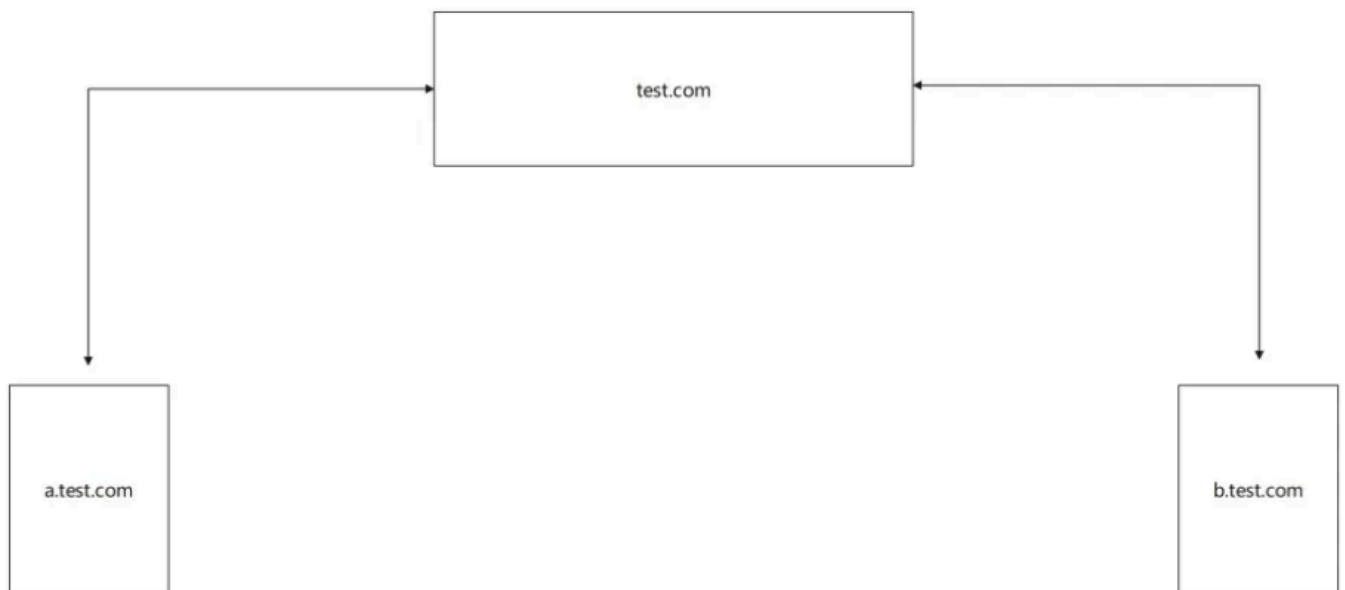
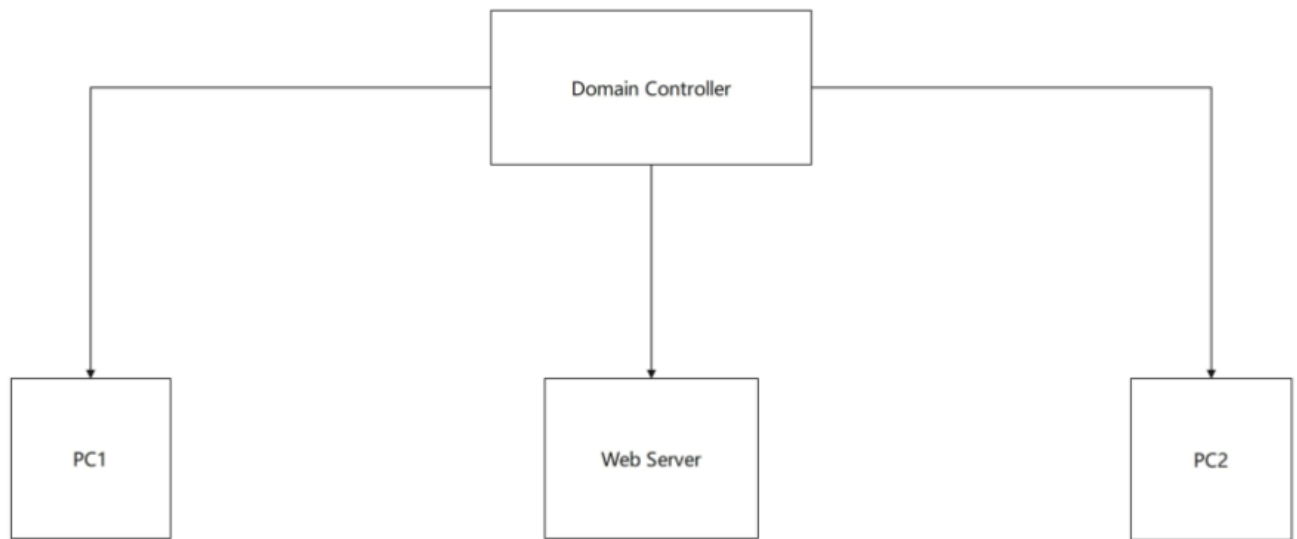
- 1 • 账号集中管理
- 2 • 软件集中管理
- 3 • 环境集中管理
- 4 • 增强统一安全性

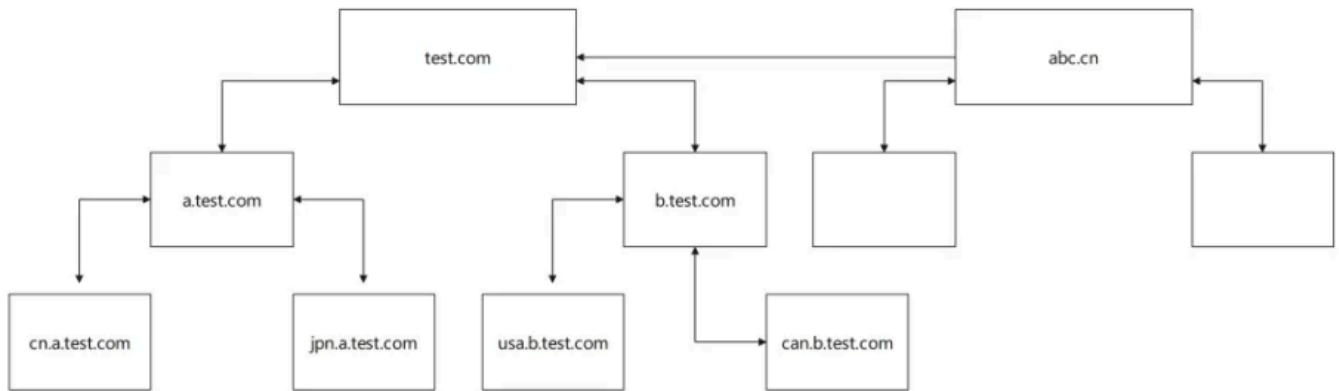
2.7 域环境架构



- 1 域控制器
- 2 成员服务器
- 3 客户机
- 4 独立服务器
- 5 见图：（单域，父域，子域，域树，域森林）
- 6 单域是指网络环境中只有一个域，建立一个单独的域足以。
- 7 父子域在一个域中划分出多个域，被划分的域为父域，划分出来的域为子域。
- 8 域树中的命名空间具有连续性，并且域名层次越深，级别越低。
- 9 域林是指一个或多个没有形成连续名字空间的域树组成的域树集合。







2.8 域环境安全



- 1 信息收集：了解当前网络架构和权限分布
- 2 权限提升：将当前控制权限提升解决限制
- 3 代理隧道：解决内网域中出网和通讯限制
- 4 横向移动：利用漏洞和口令等扩大后续战果
- 5 权限维持：植入后门或票据等进行后续控制

3.演示案例

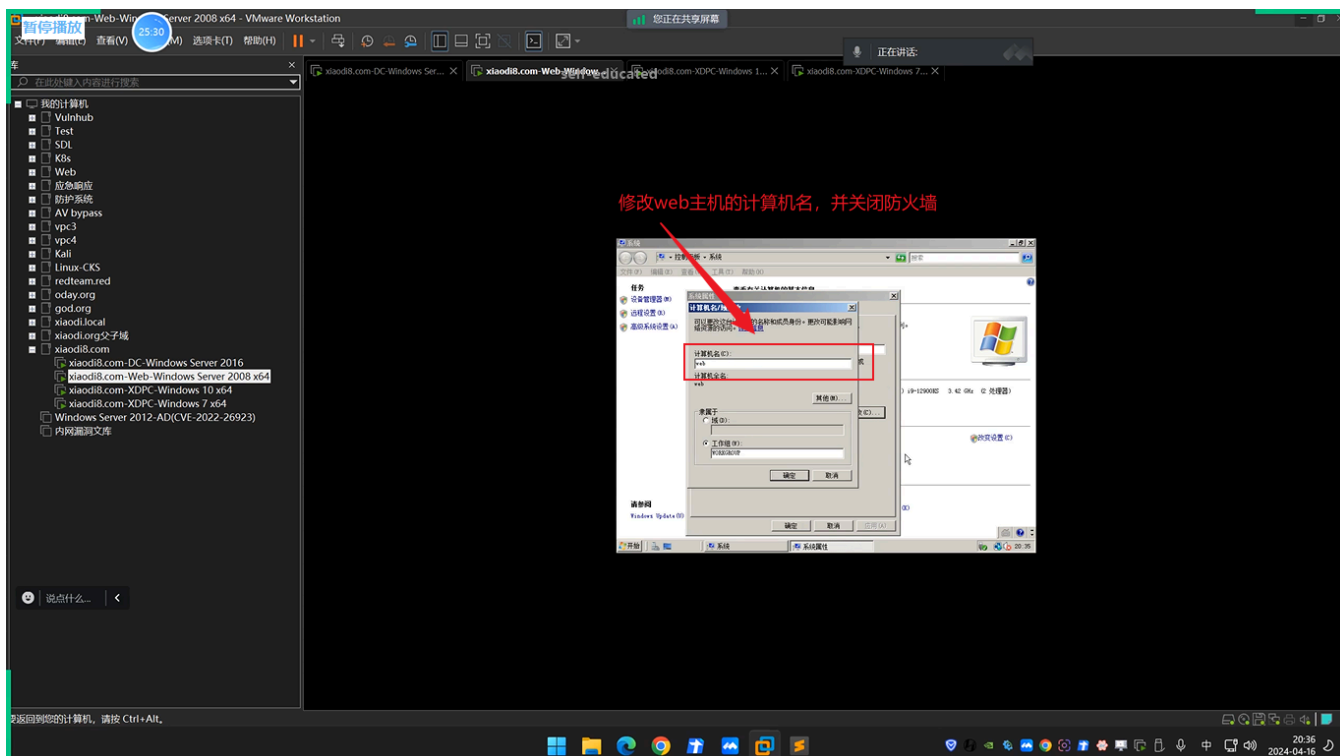
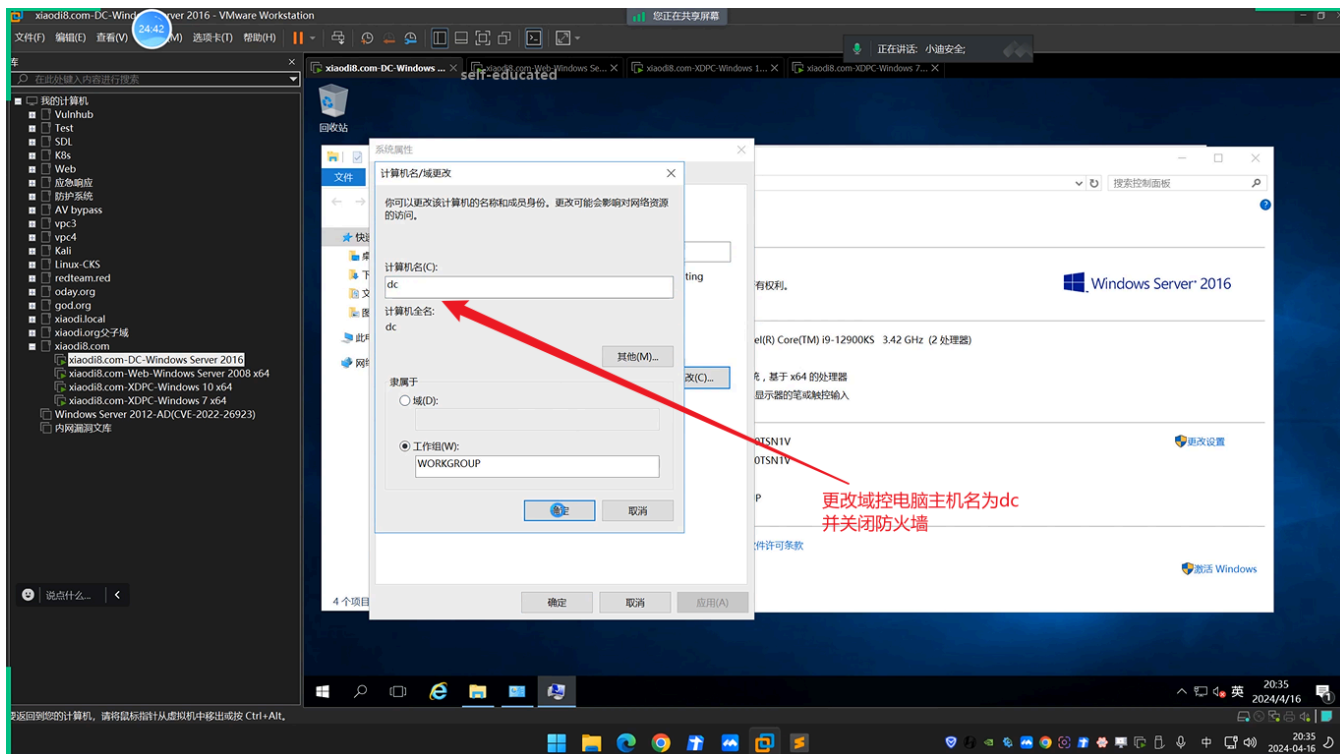
3.1 内网单域架构-环境搭建-服务安装&加入域内

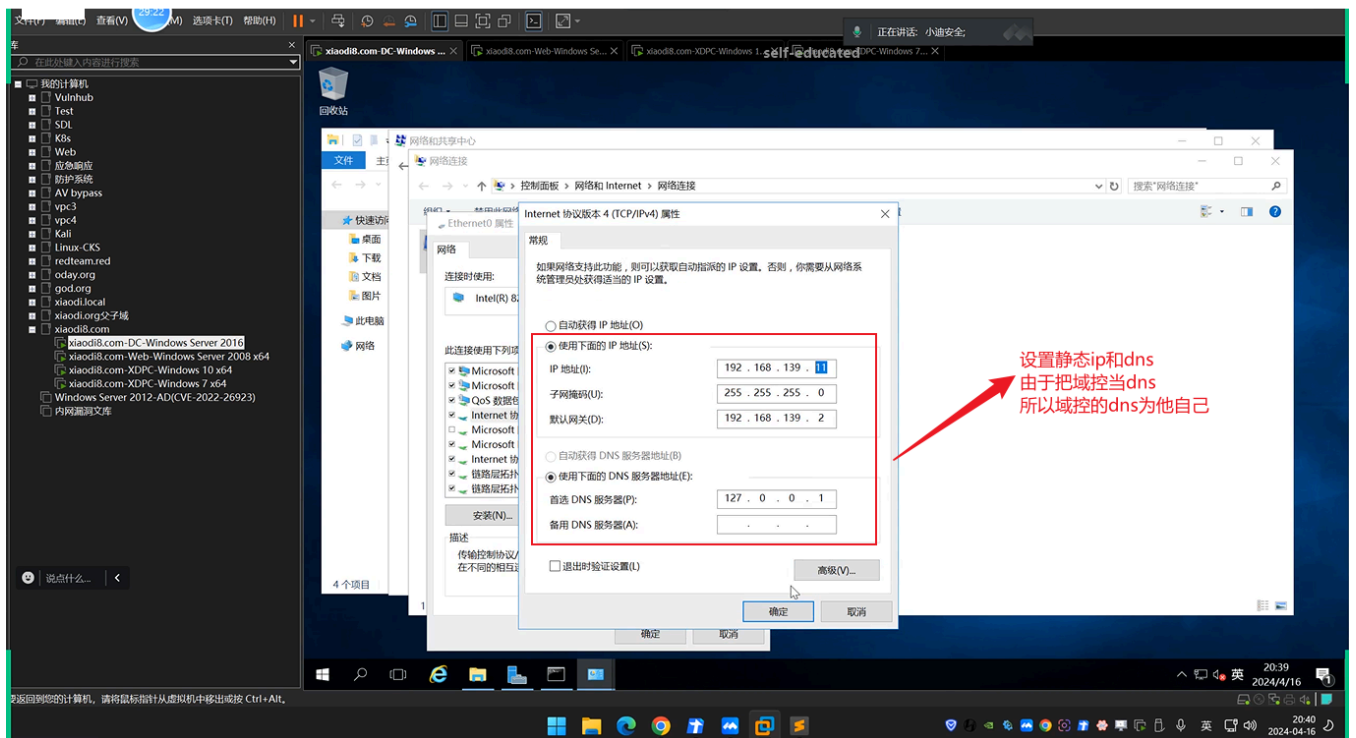
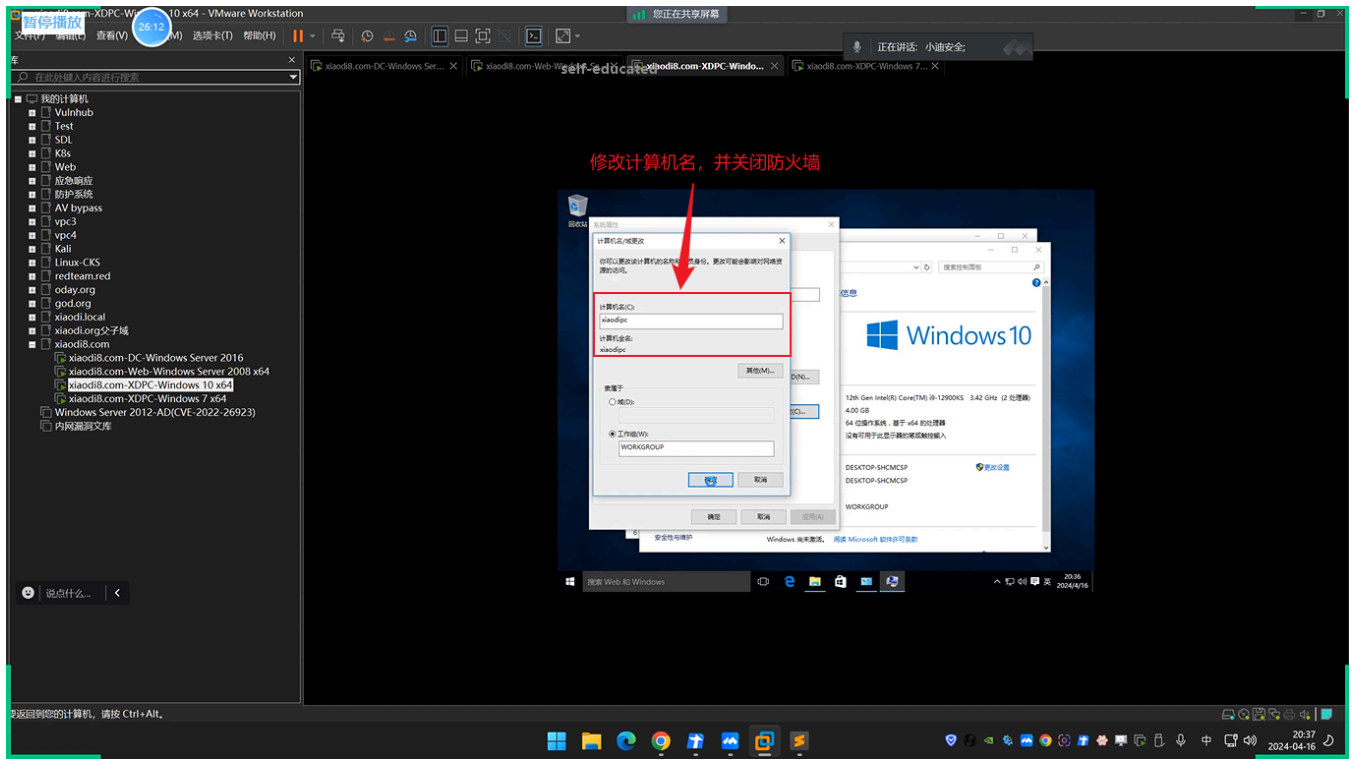
以一台DC，一台WEB和一台个人PC为例。

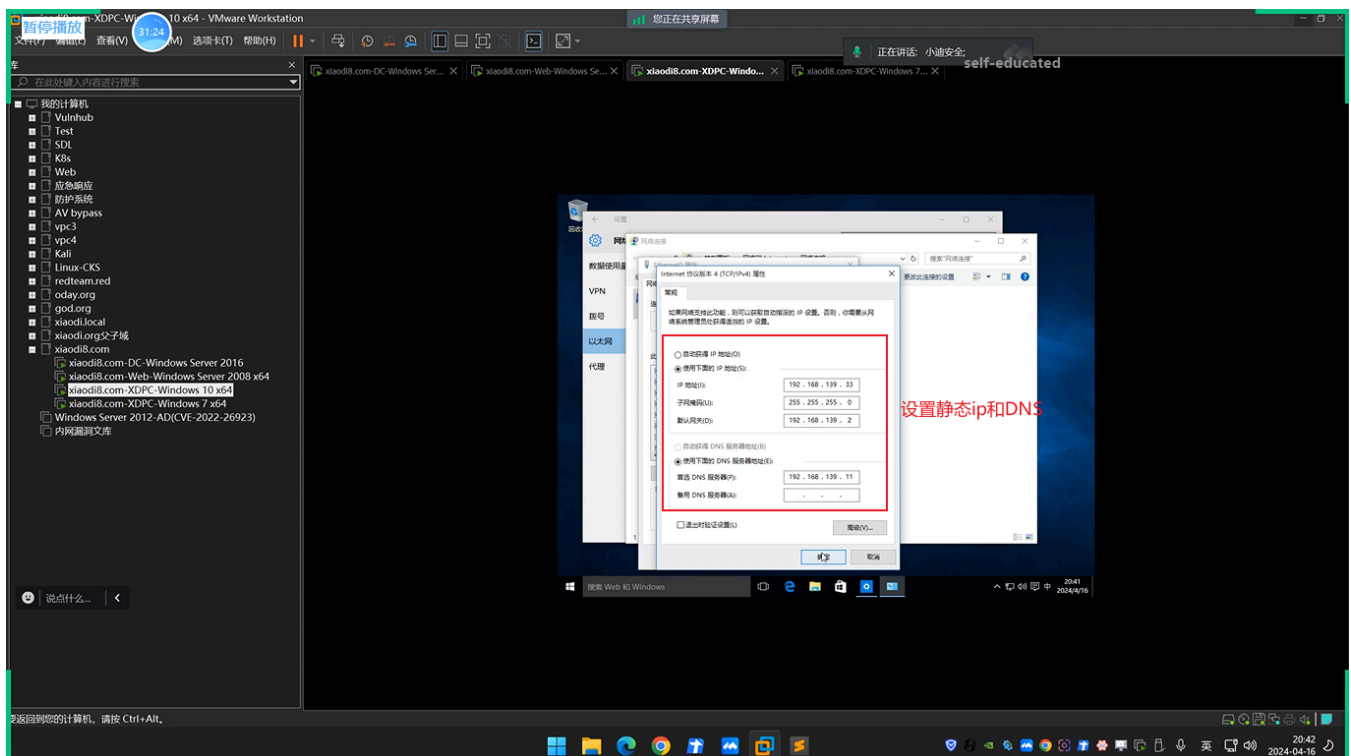
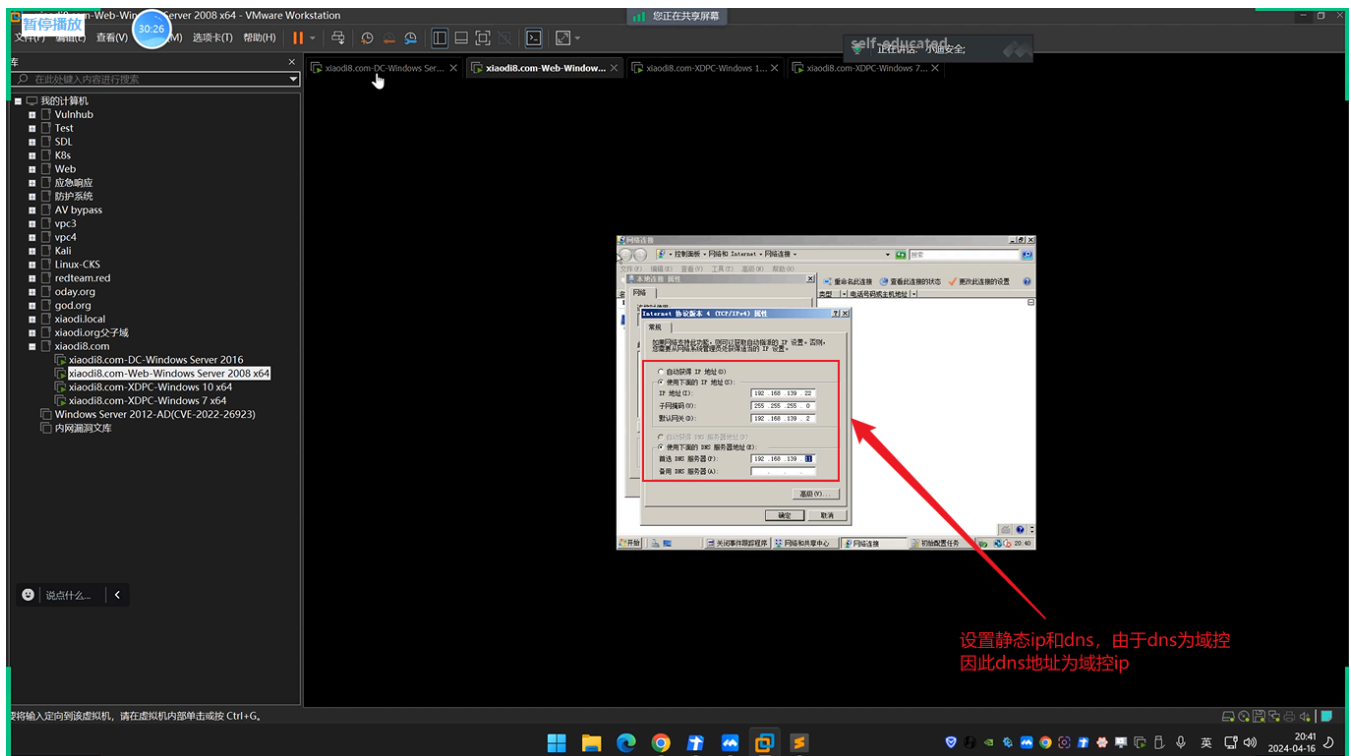


- 1 准备工作：
- 2 关闭防火墙并改计算机名
- 3 计算机网络配置静态IP和DNS

(1) 准备工作：

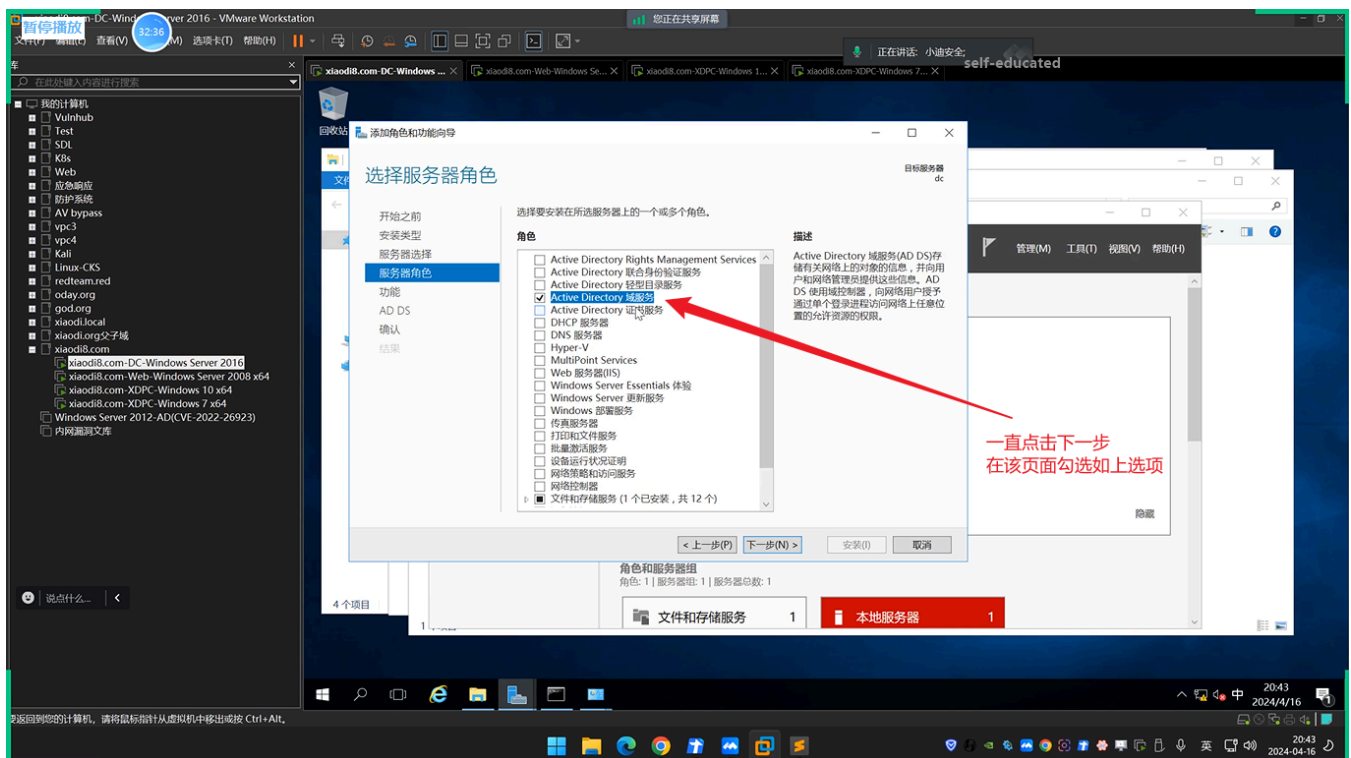
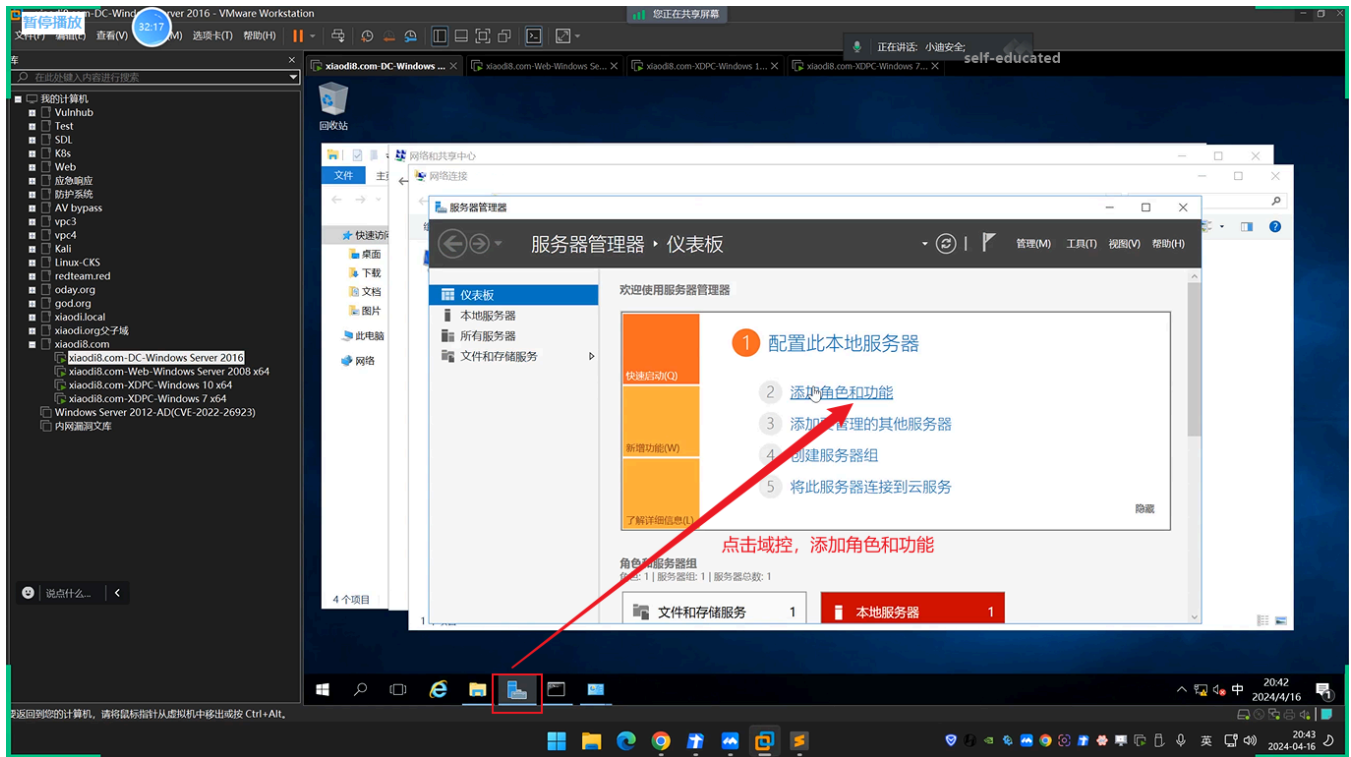


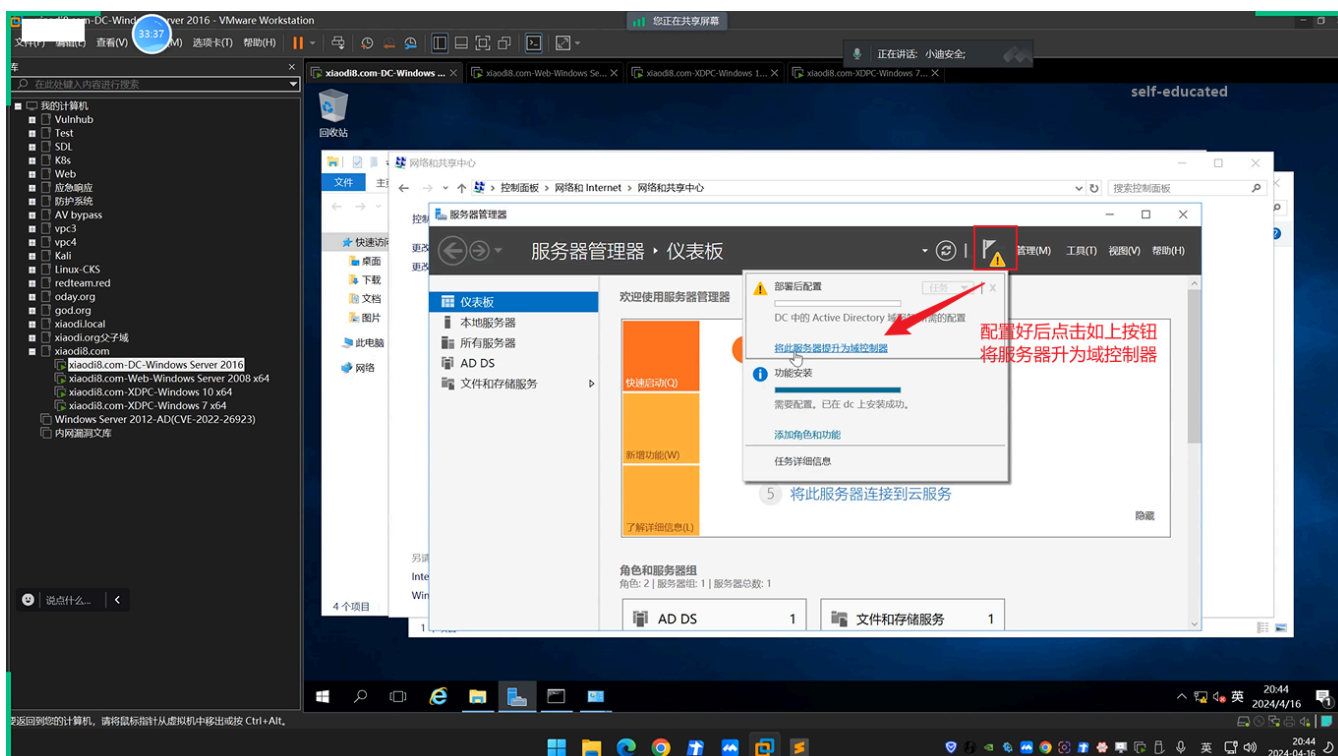
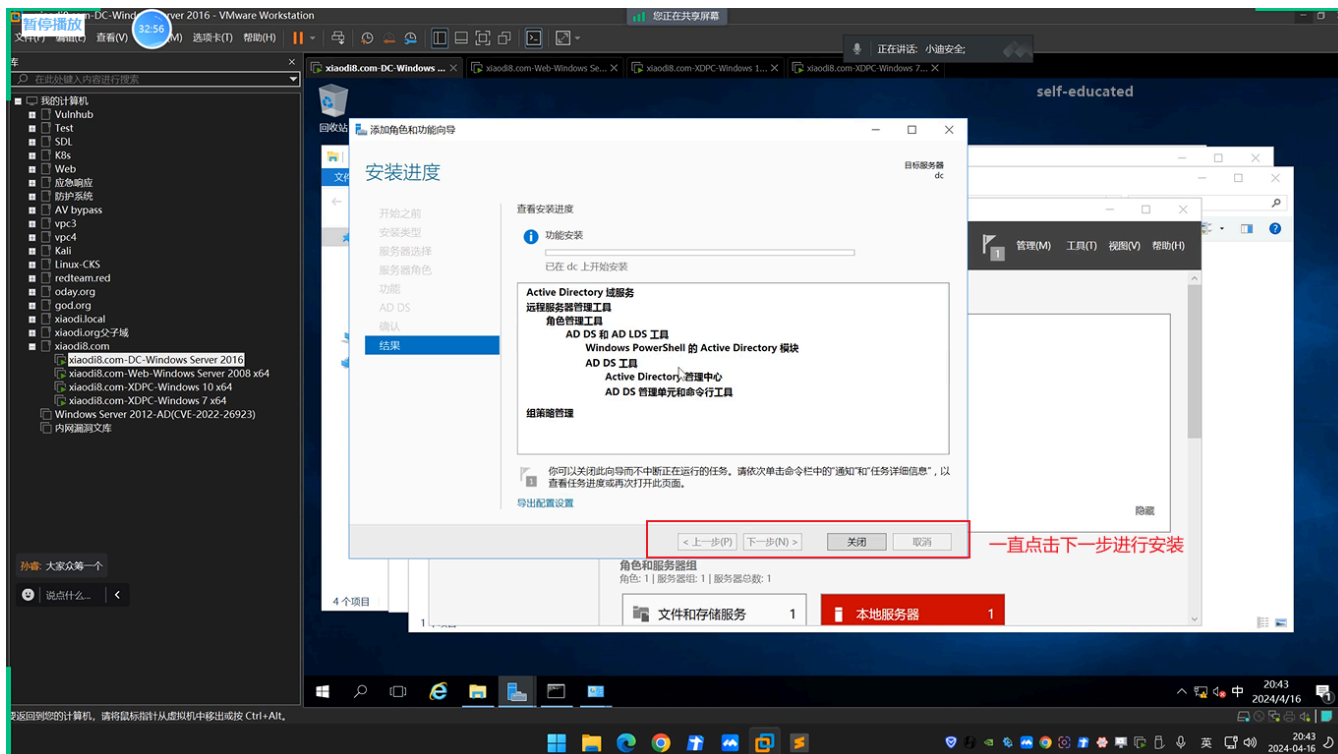


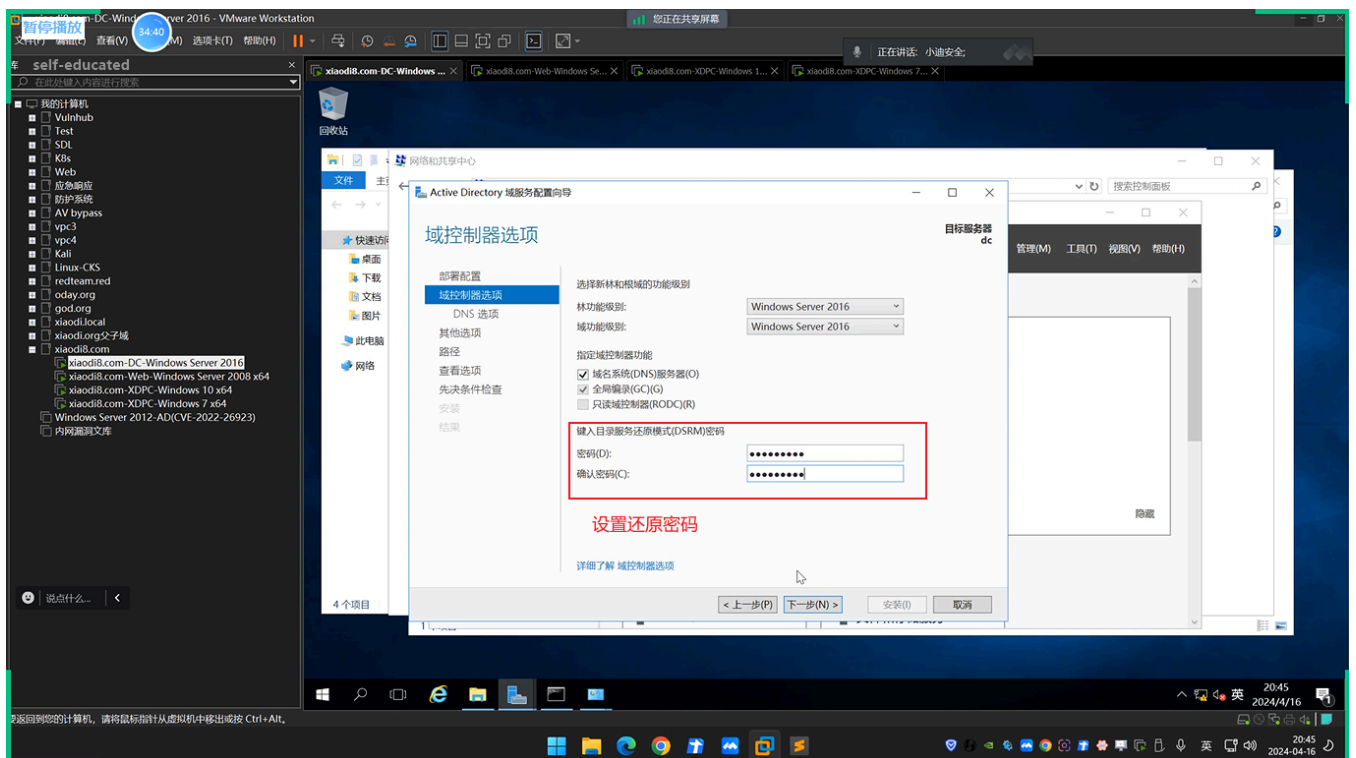
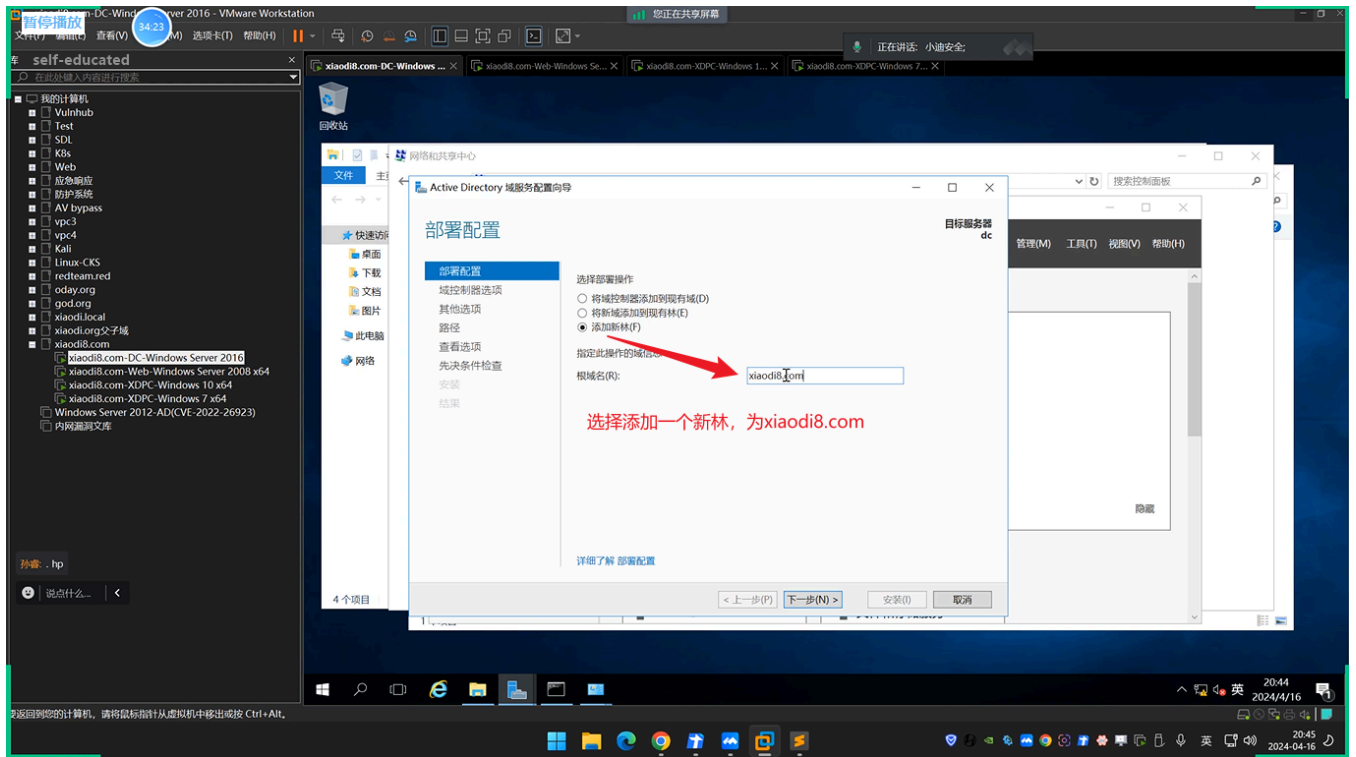


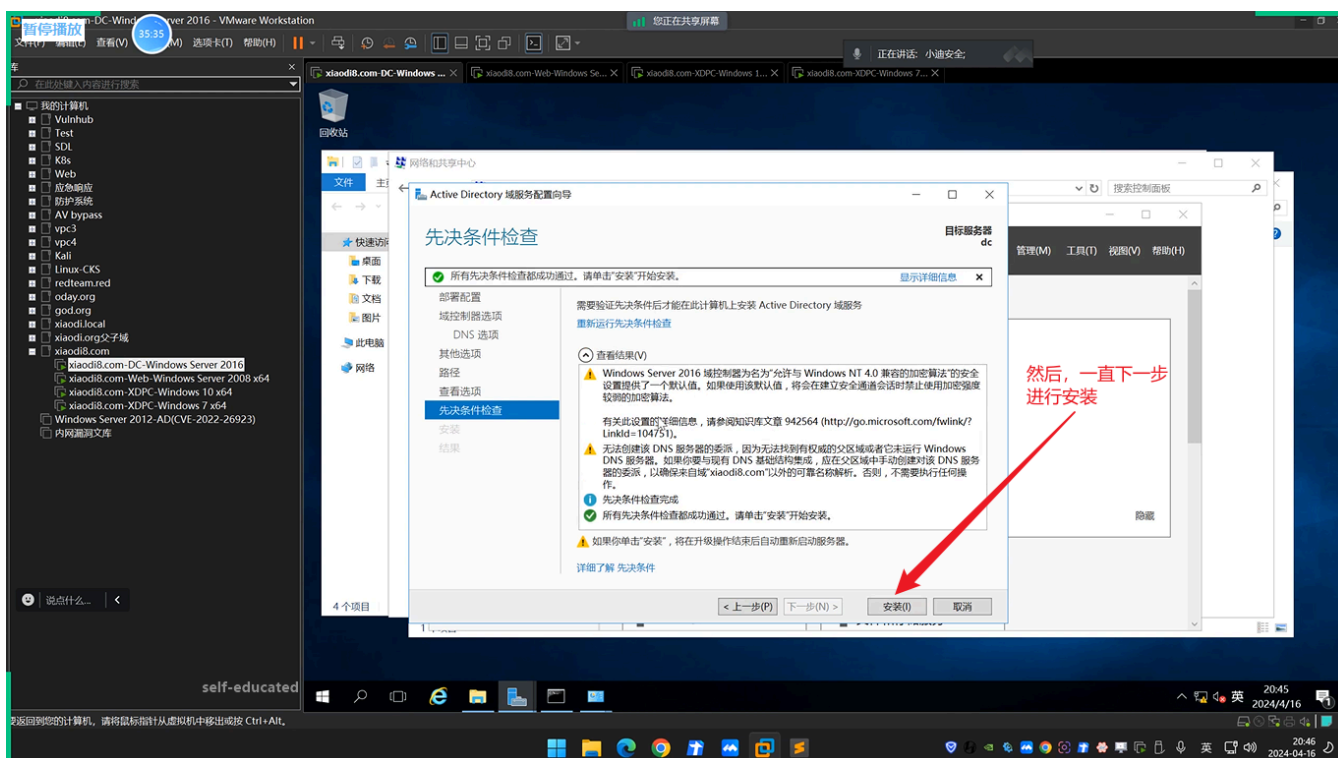
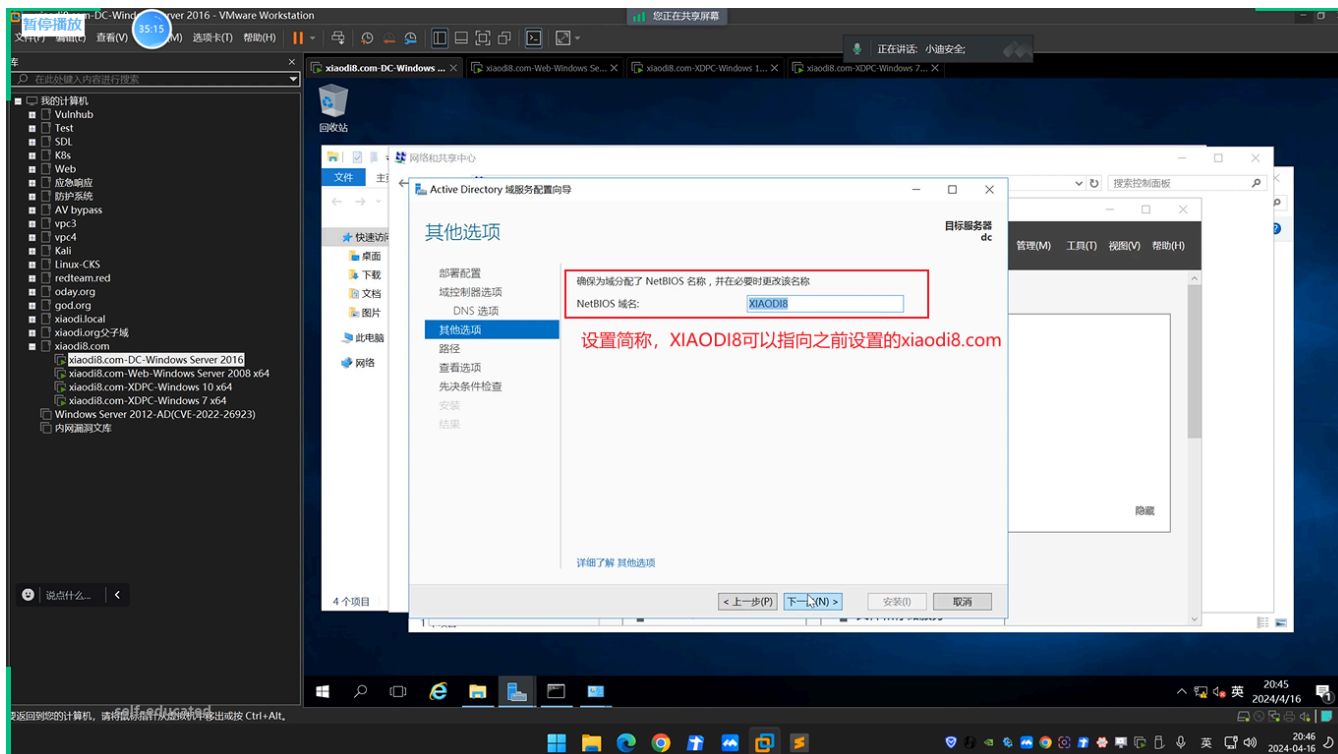
- 1 安装工作:
- 2 DC安装域控和DNS服务
- 3 提升到DC域控配置域名

(2) 安装工作:



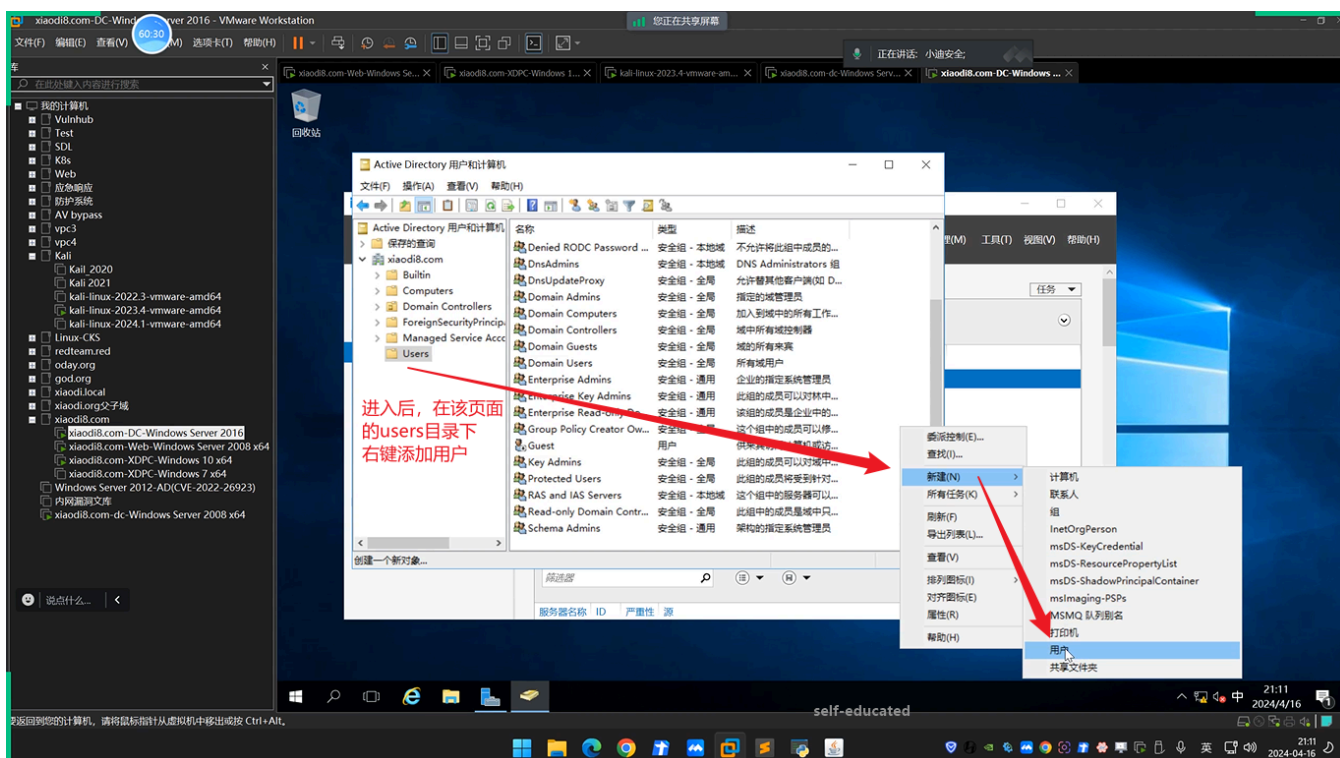
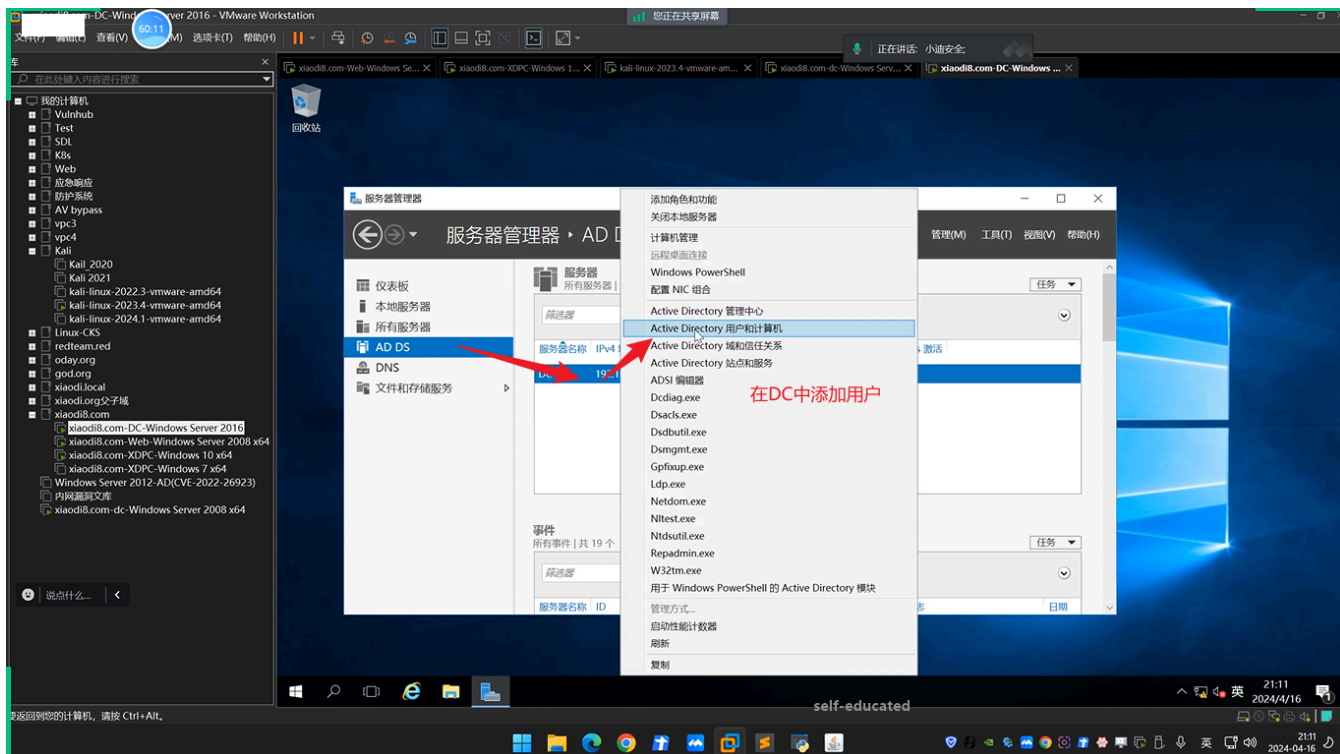


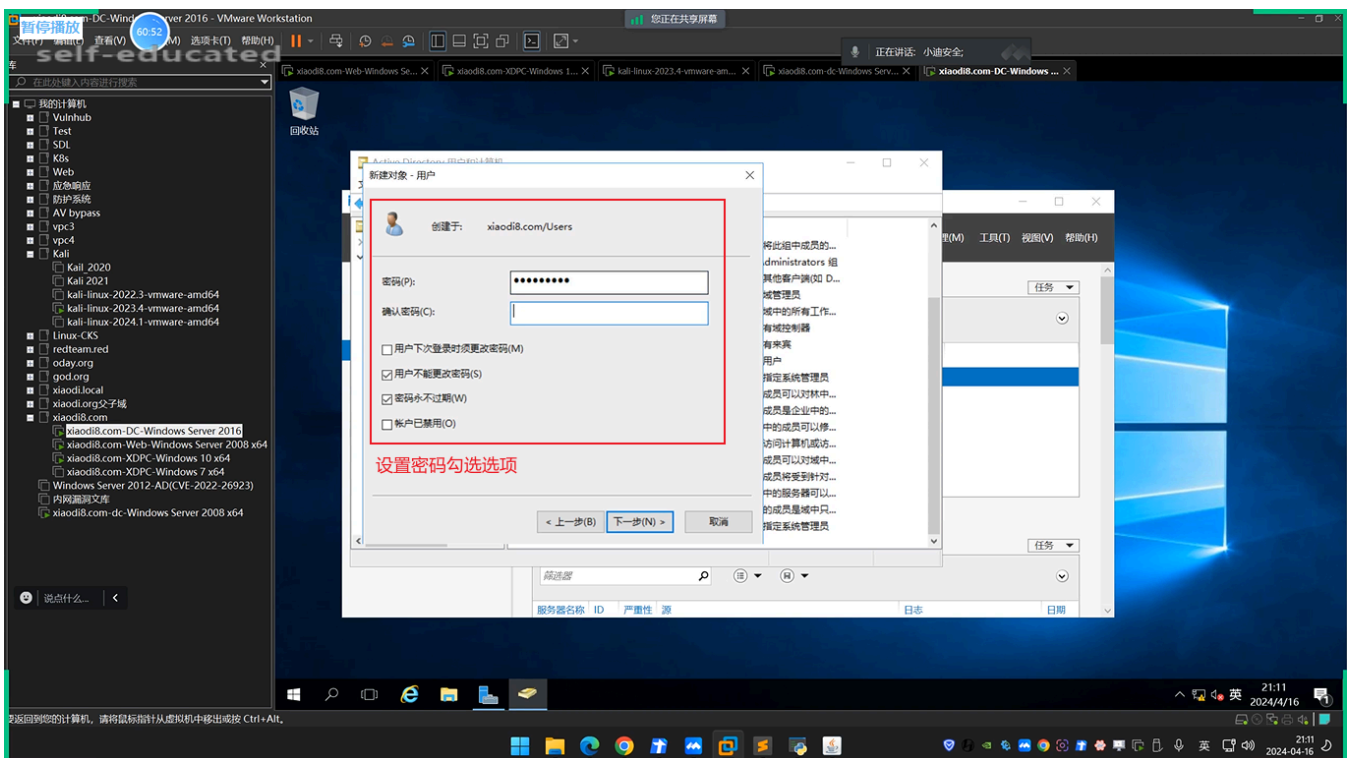
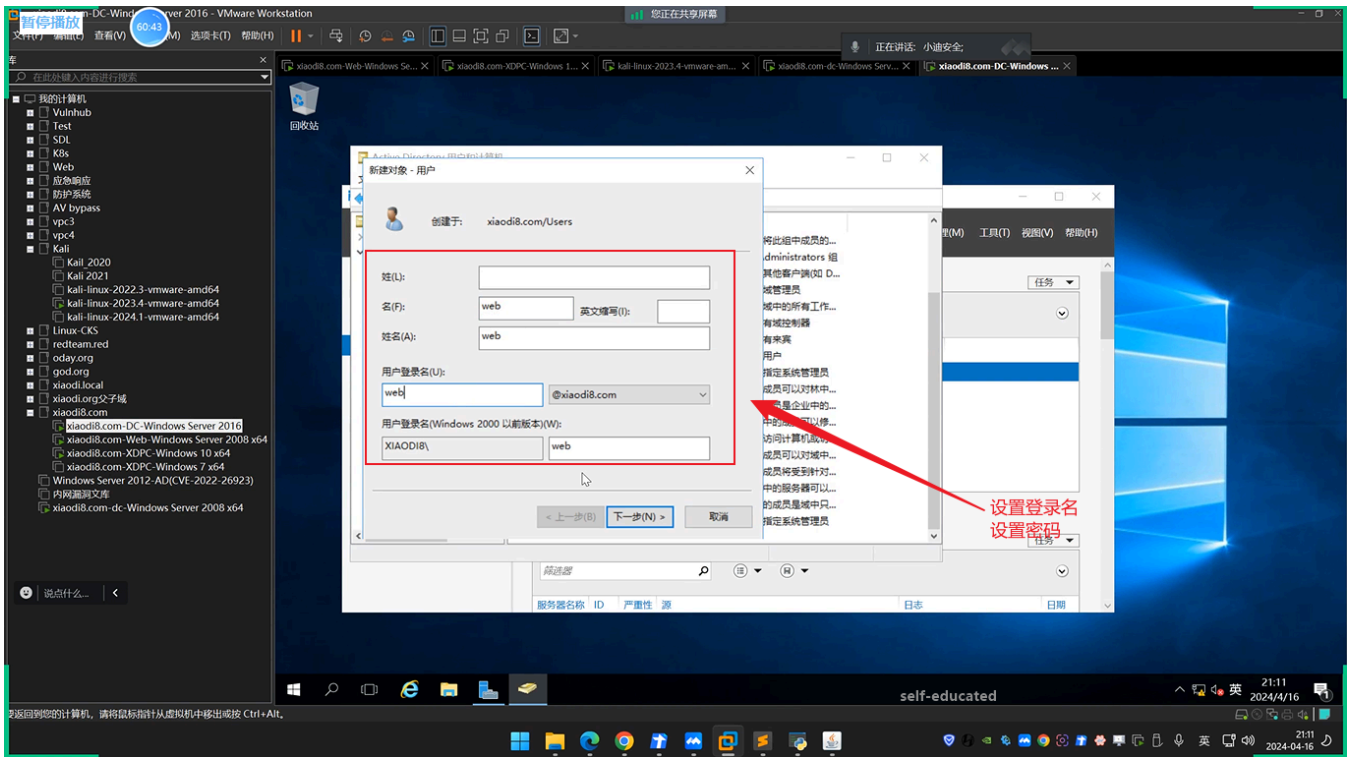


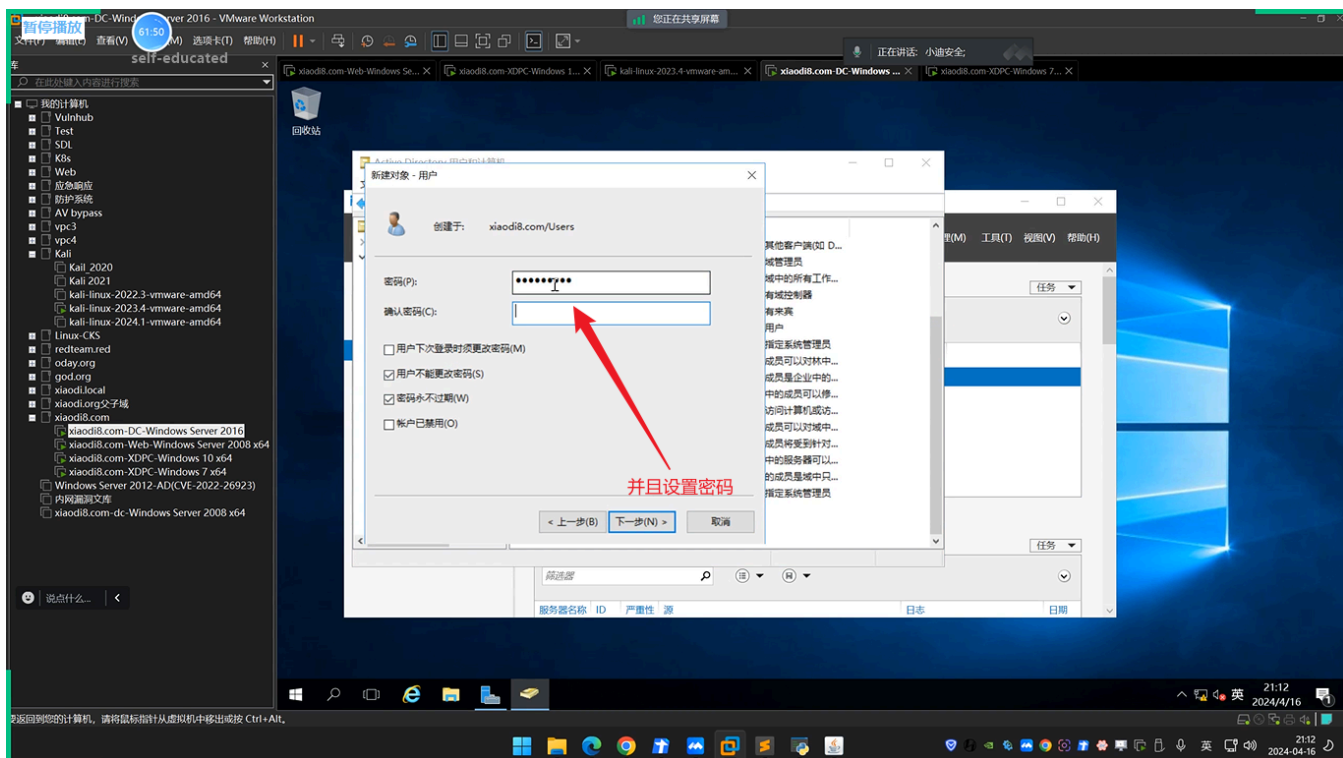
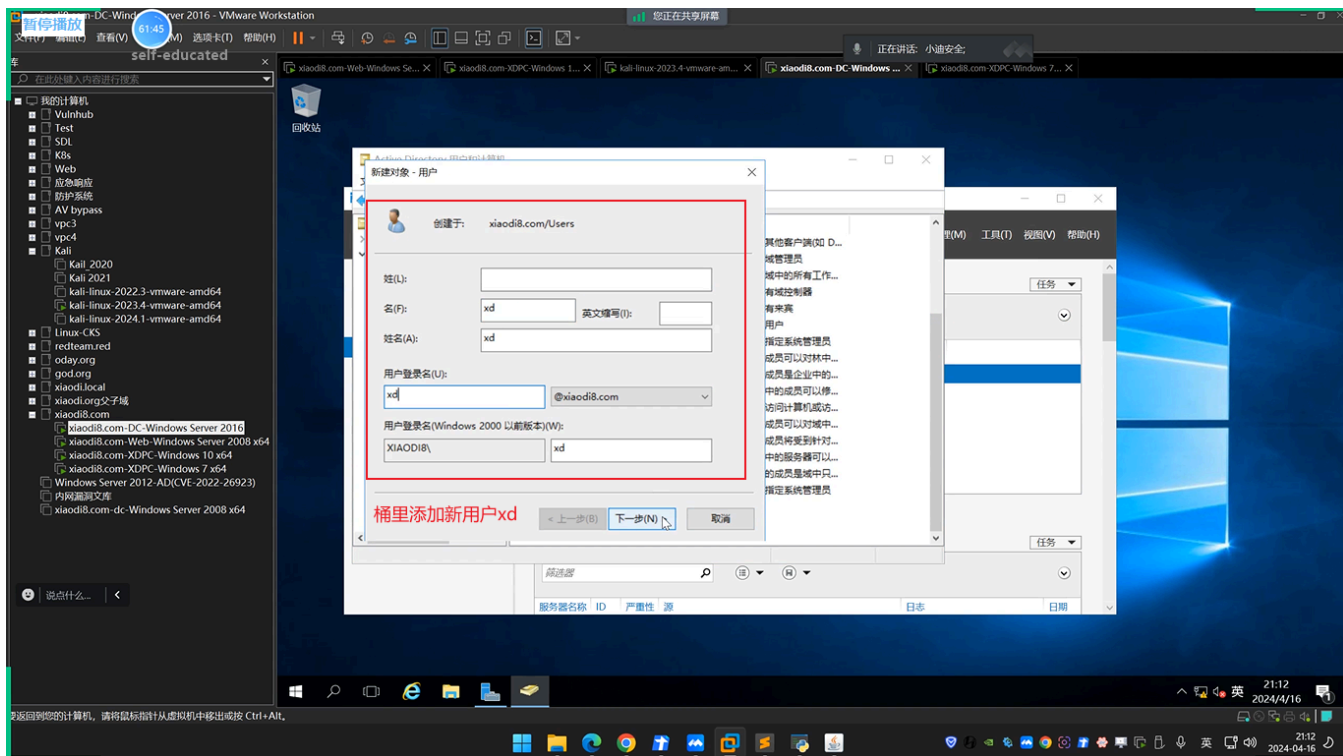


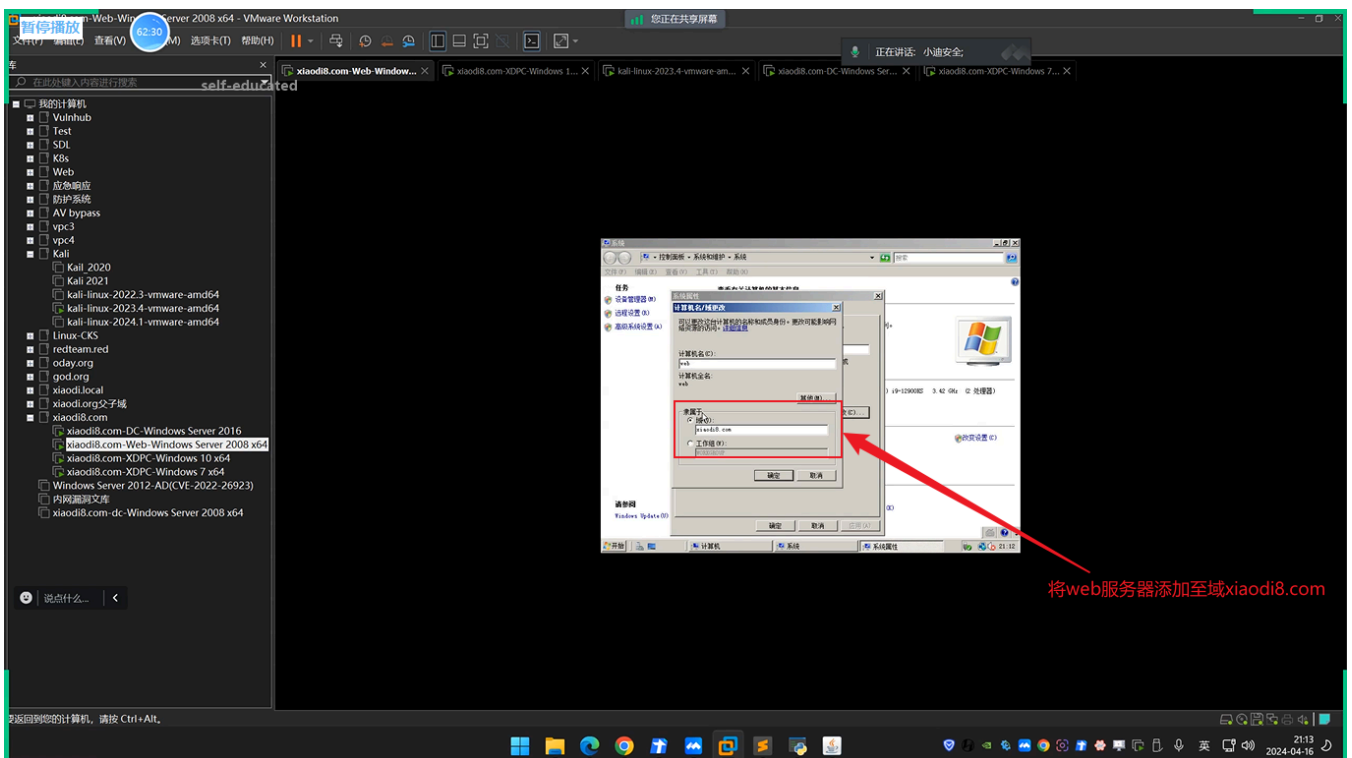
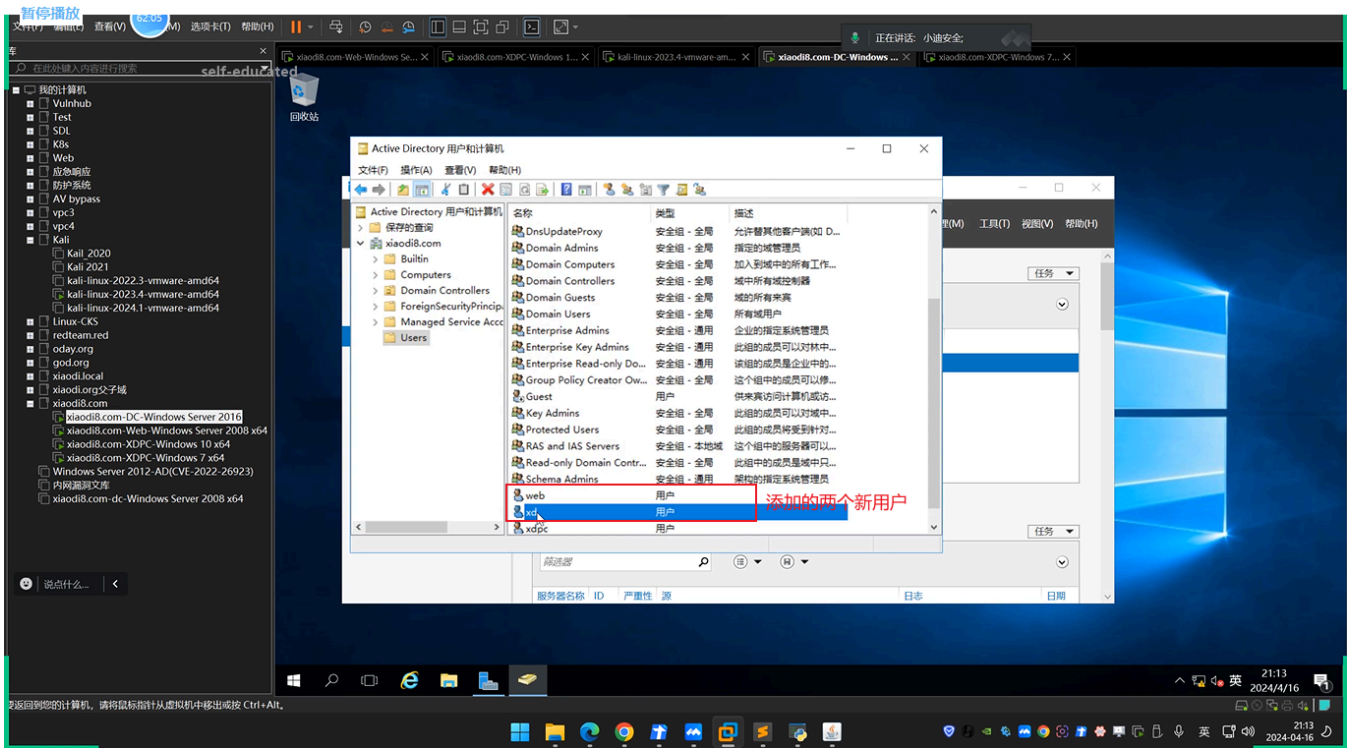
- 1 加入工作:
- 2 DC上添加域内用户
- 3 修改主机名称及加入域

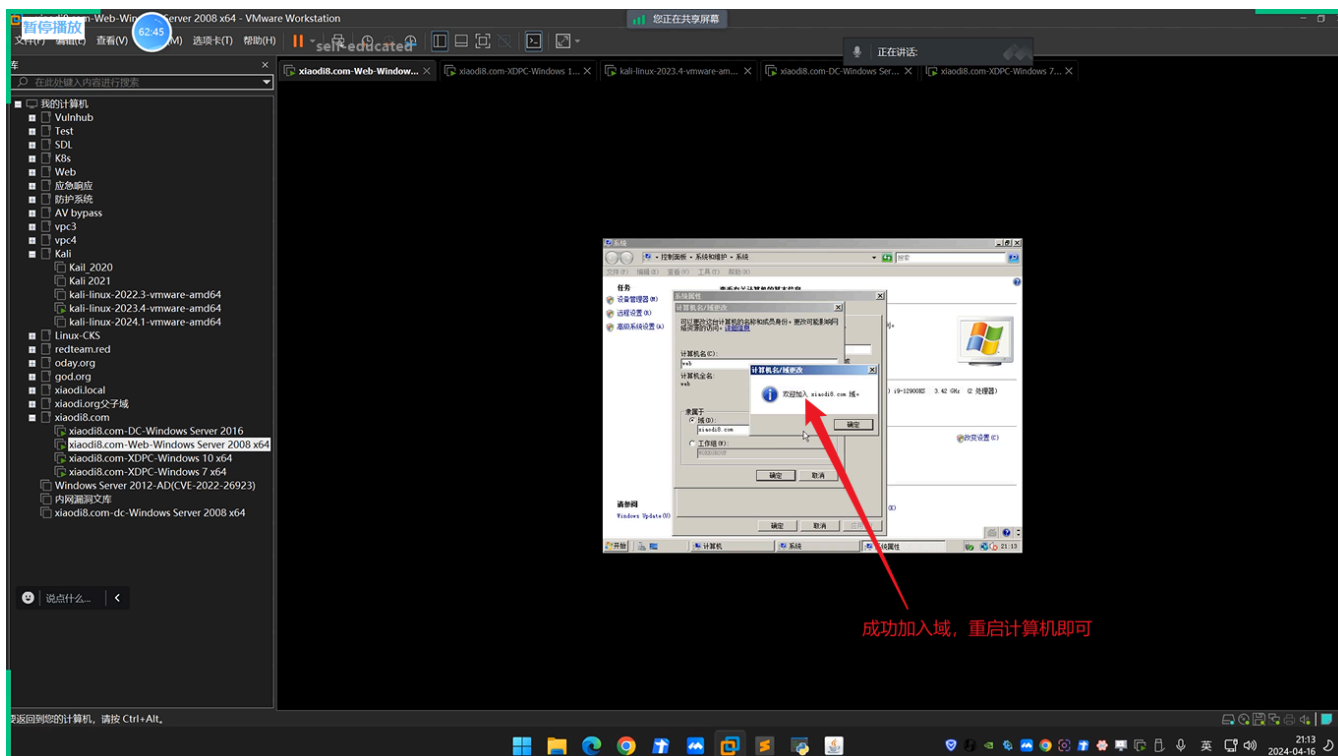
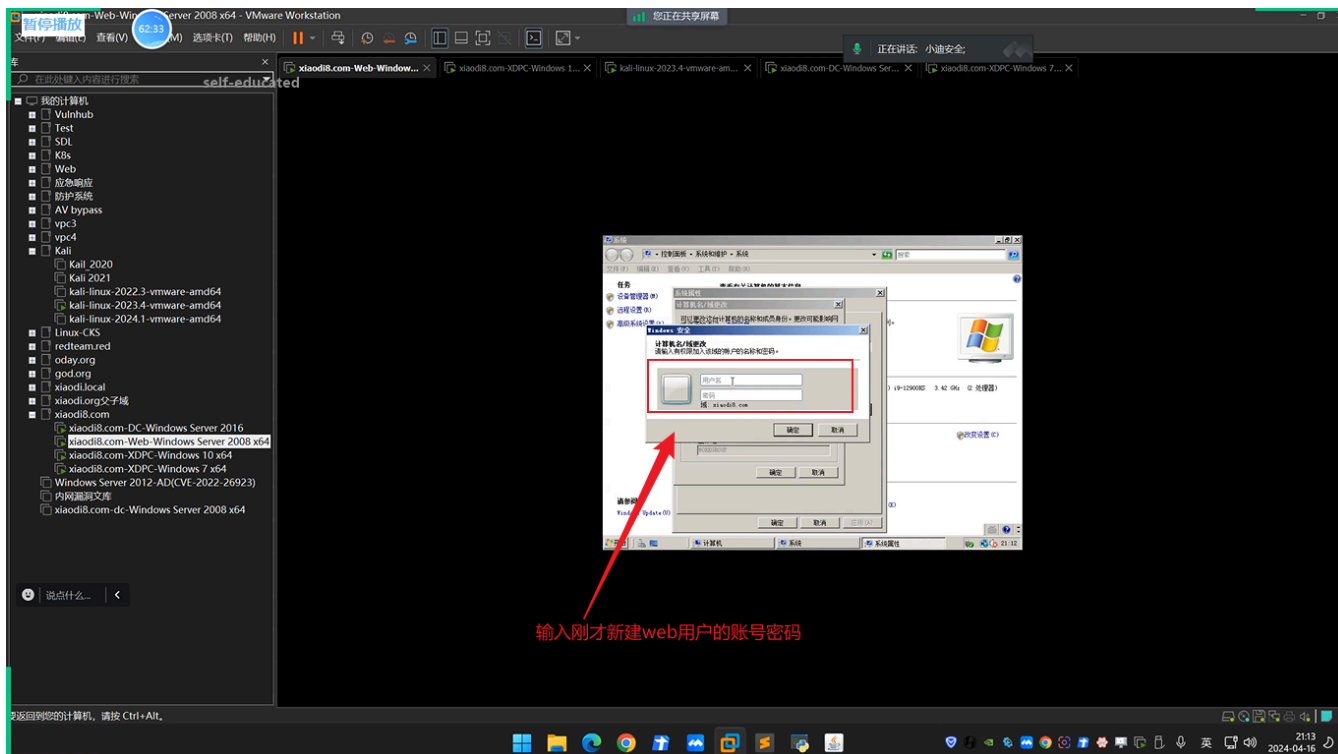
(3) 加入工作:

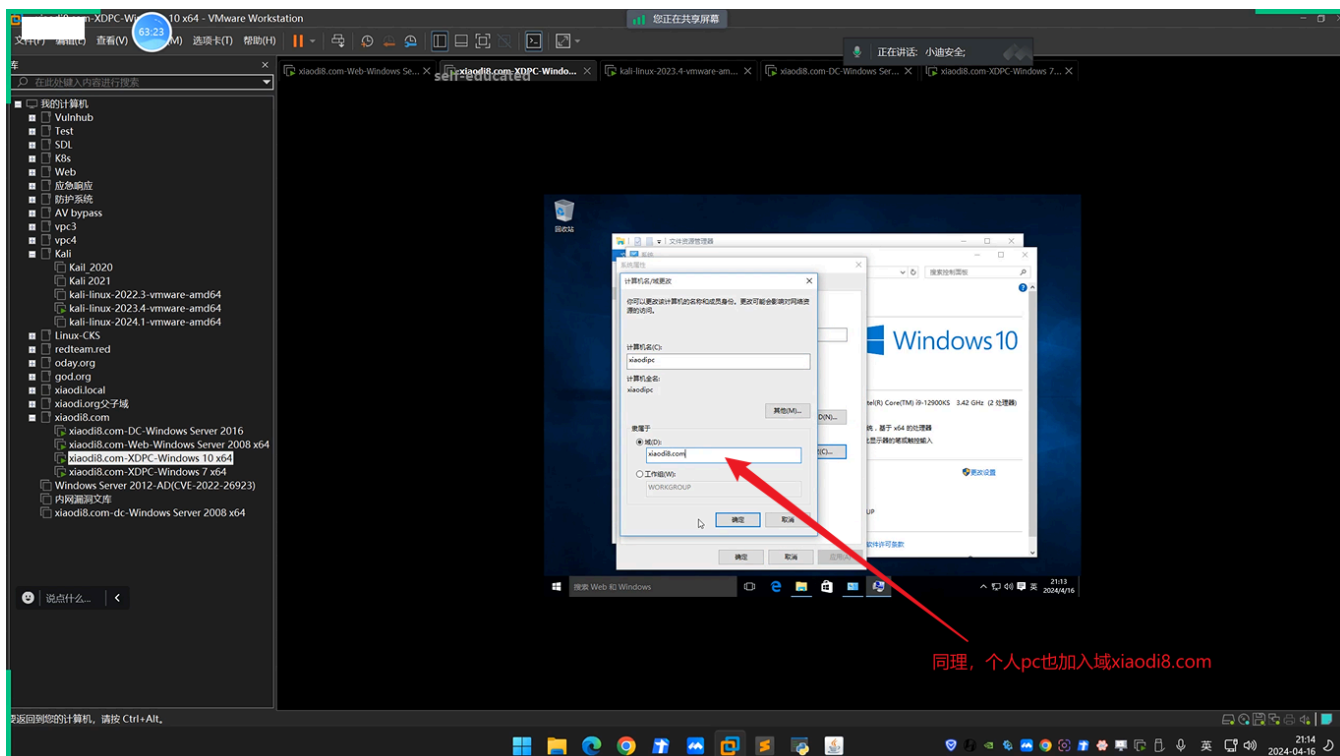
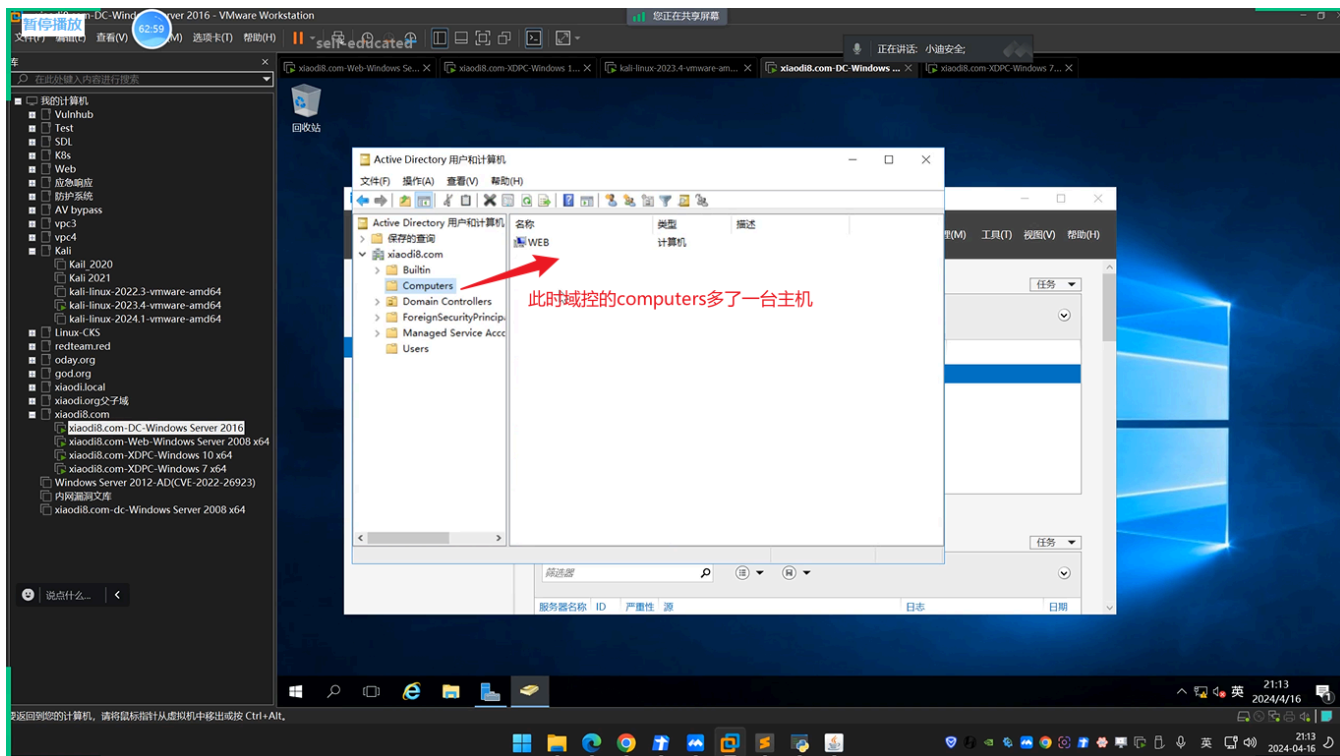


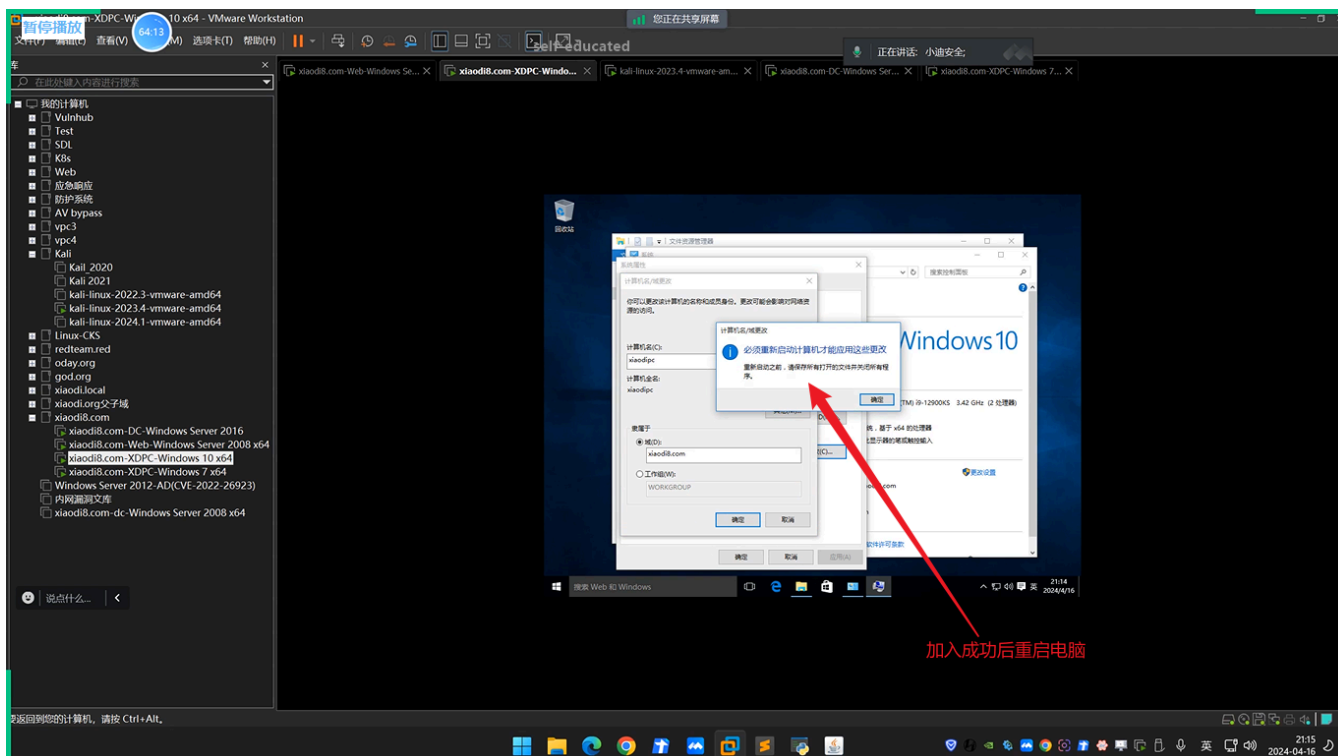
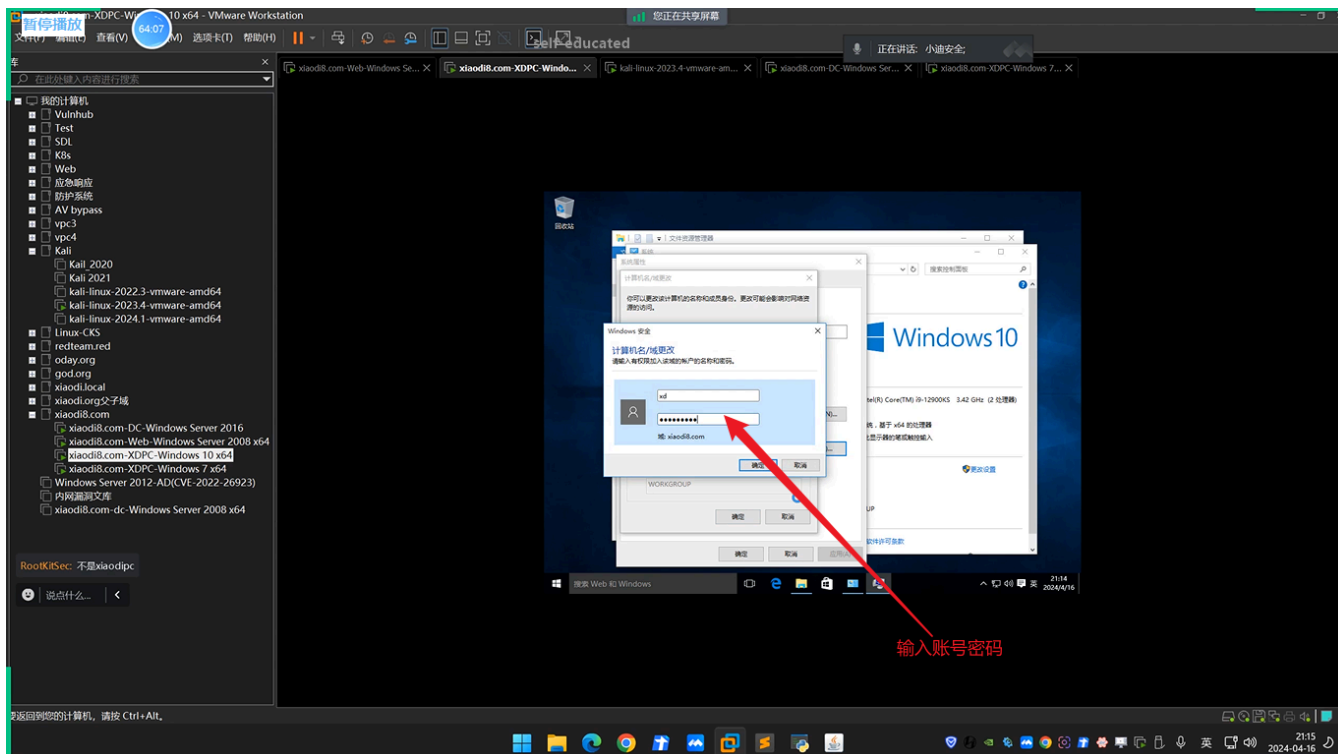












3.2 内网单域架构-信息收集-手工命令&工具插件

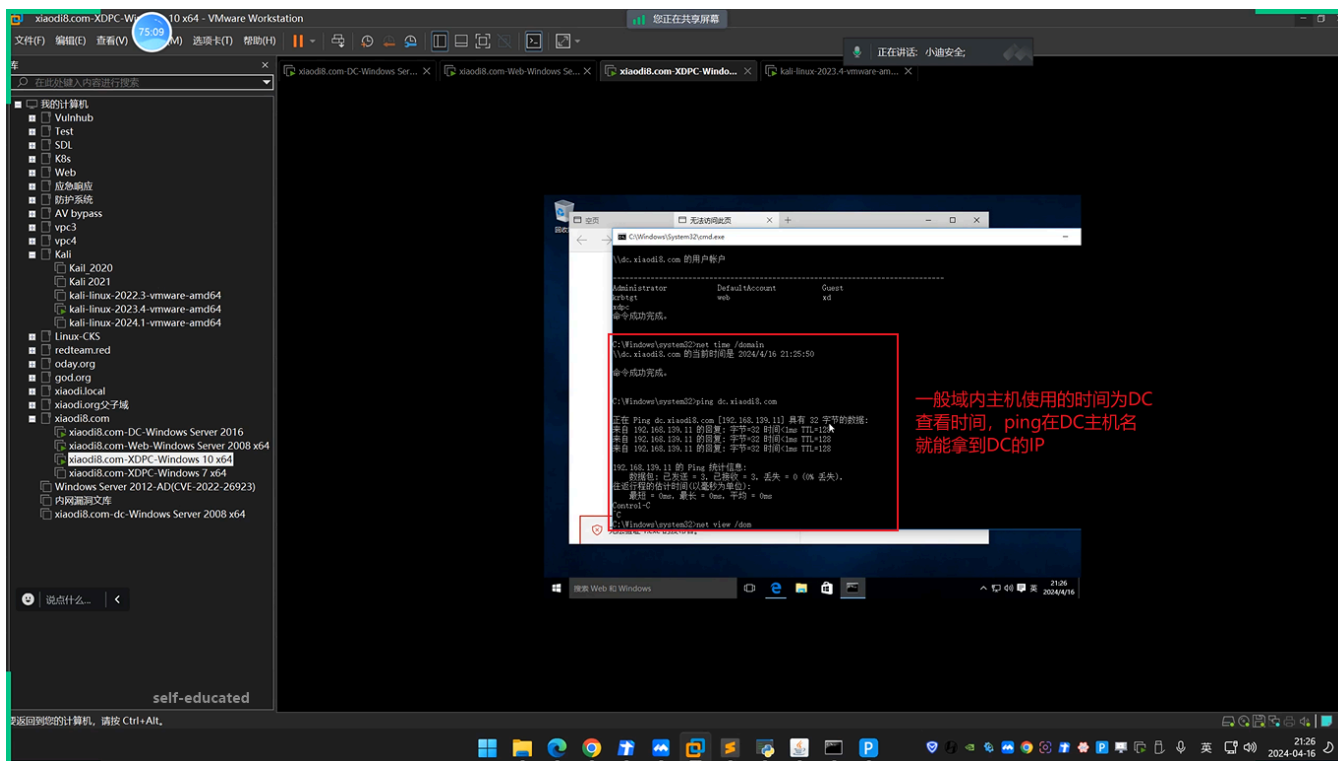
- 1 1、如何判断在域内
- 2 2、如何定位域控DC
- 3 3、如何获取其他信息
- 4 其他信息：用户及组，网络架构等
- 5 手工工具：常见命令，工具插件等
- 6 <https://mp.weixin.qq.com/s/128Ap8ohEBDweg0jNM-T5g>

(1) 如何判断在域内:

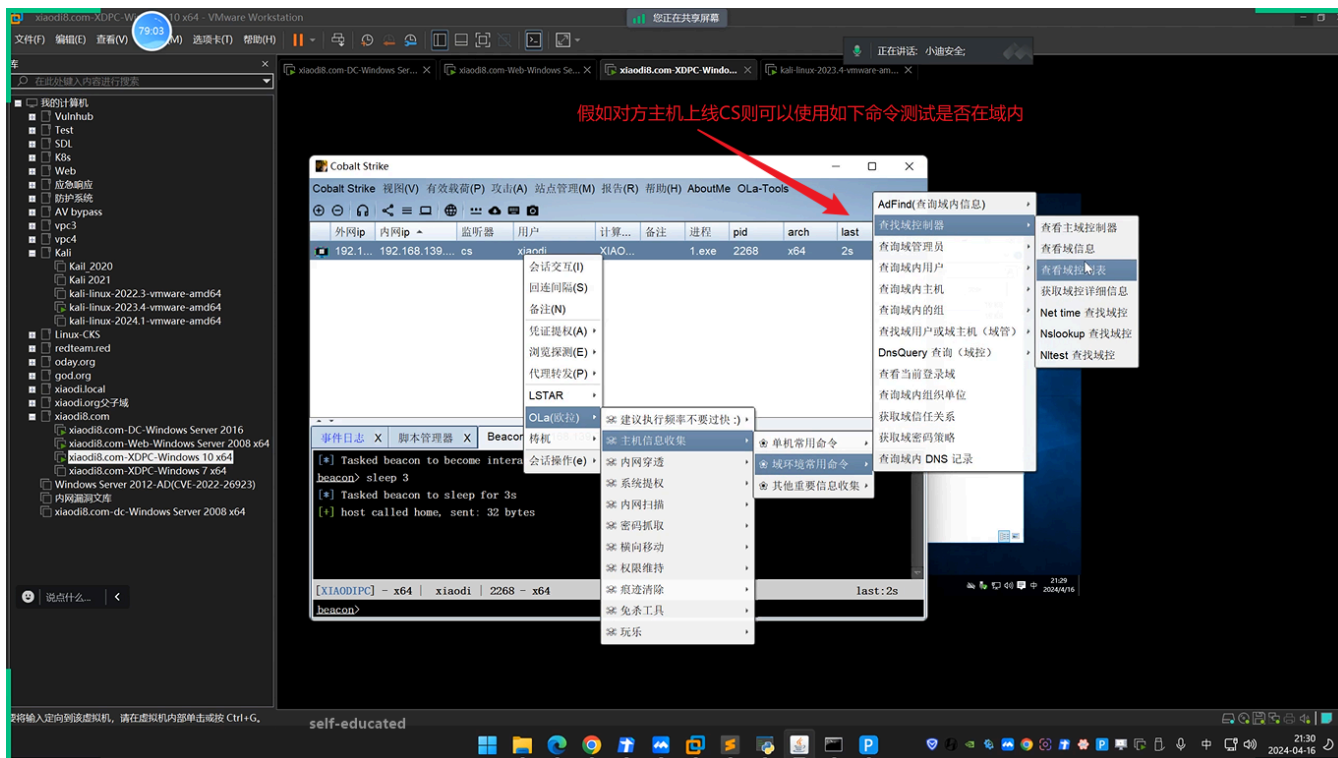
先检测权限，再使命令判断

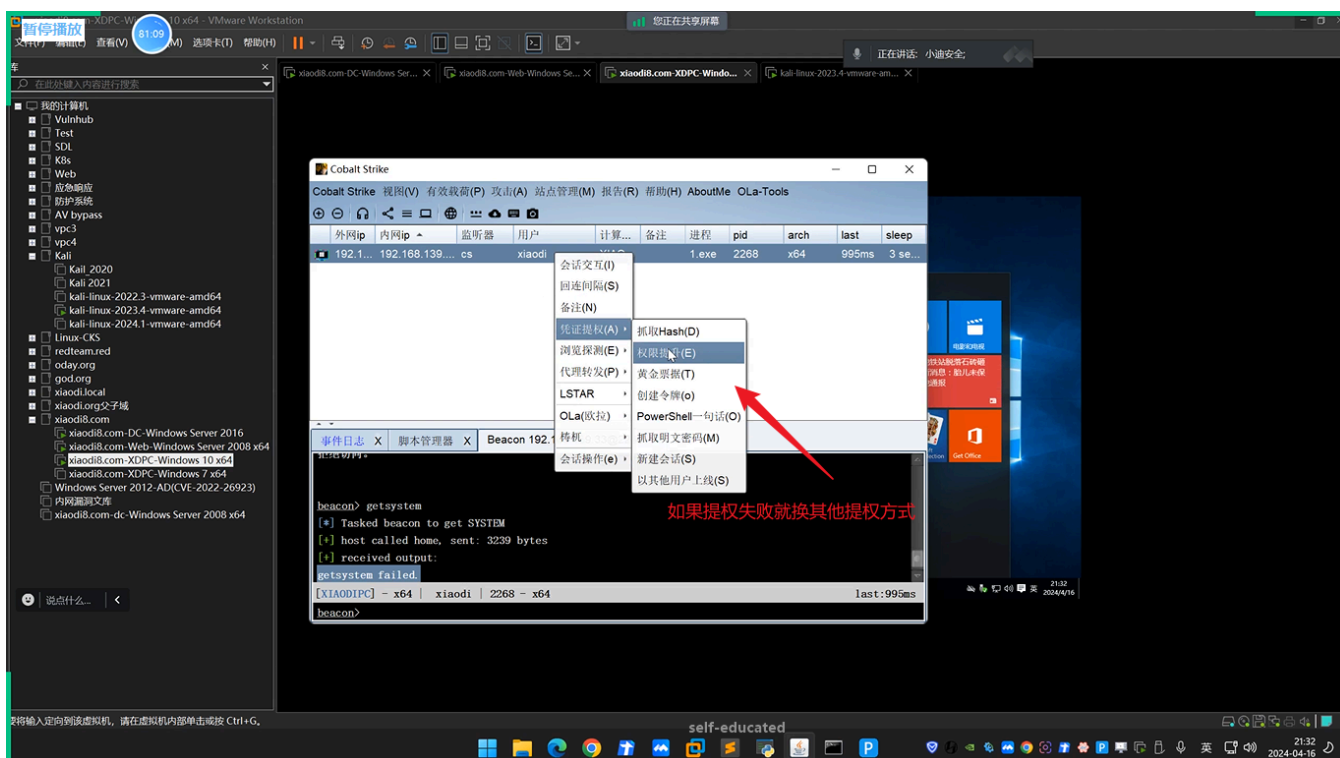
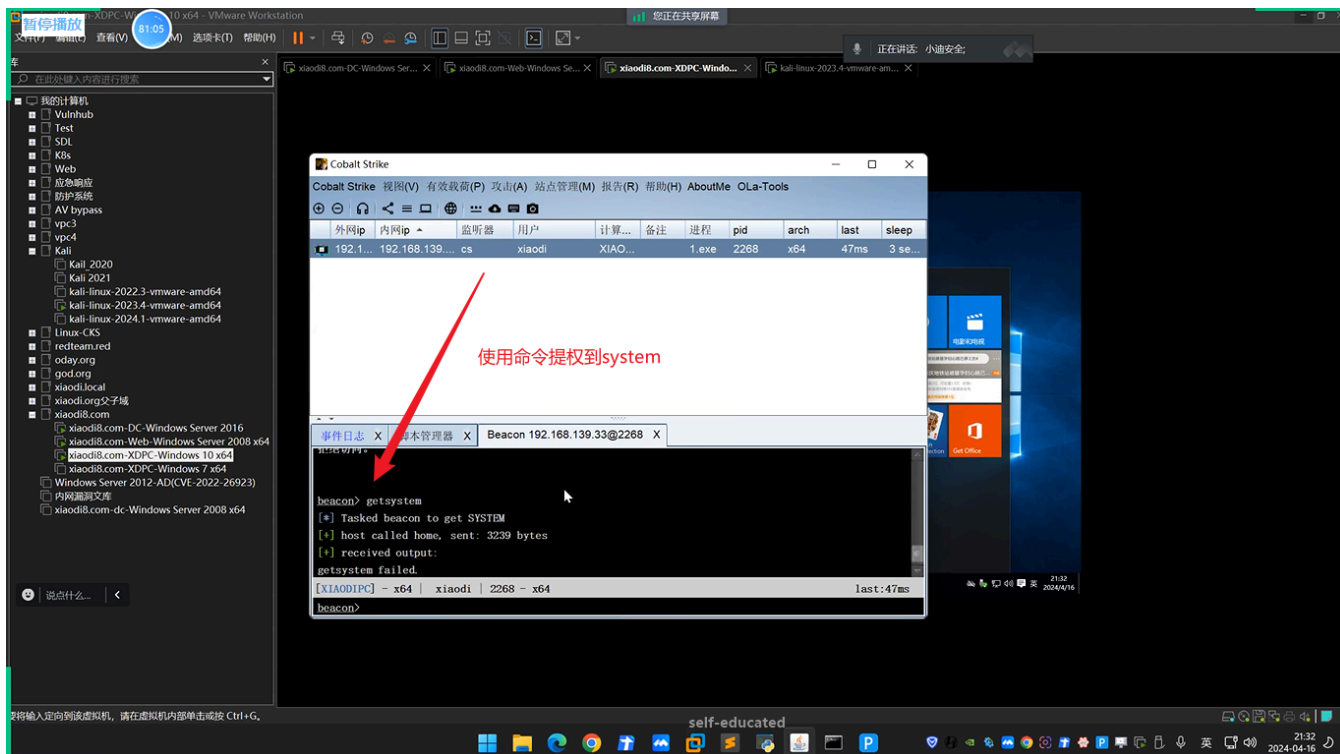
参考该网址的命令：<https://mp.weixin.qq.com/s/128Ap8ohEBDweg0jNM-T5g>

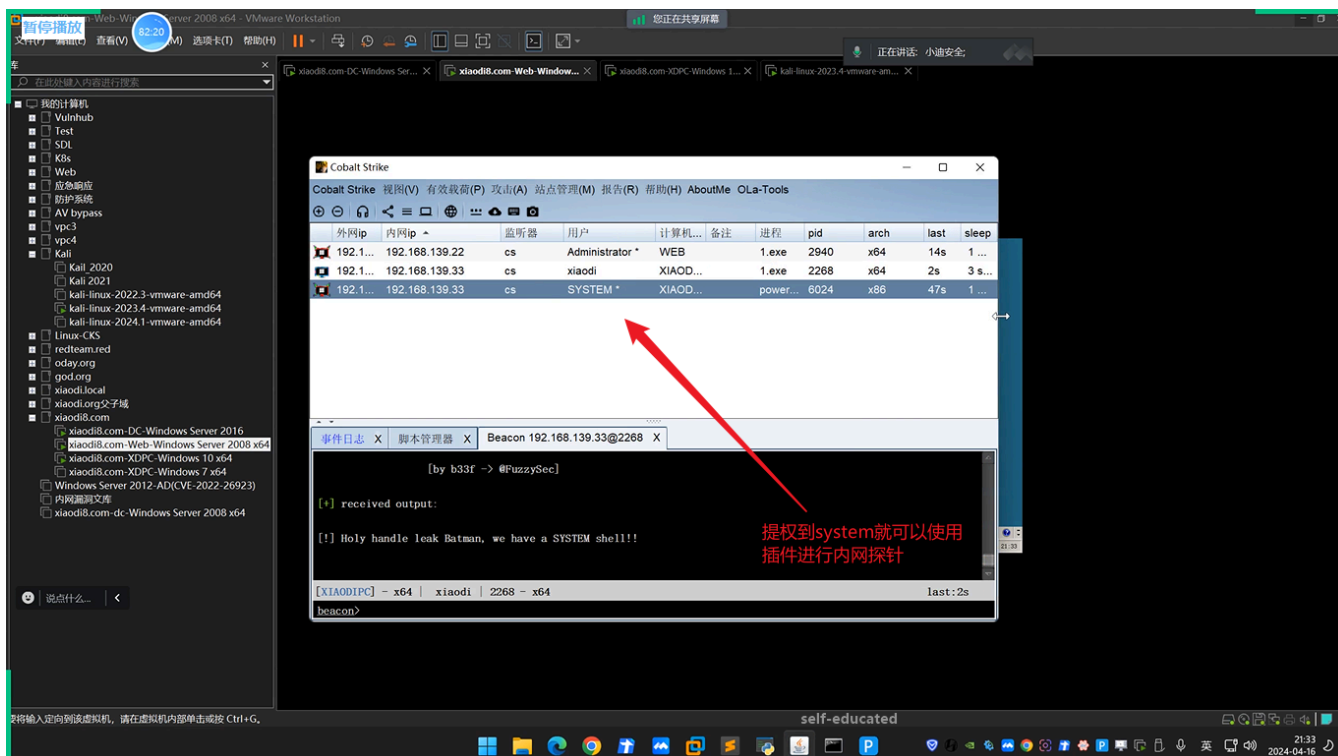
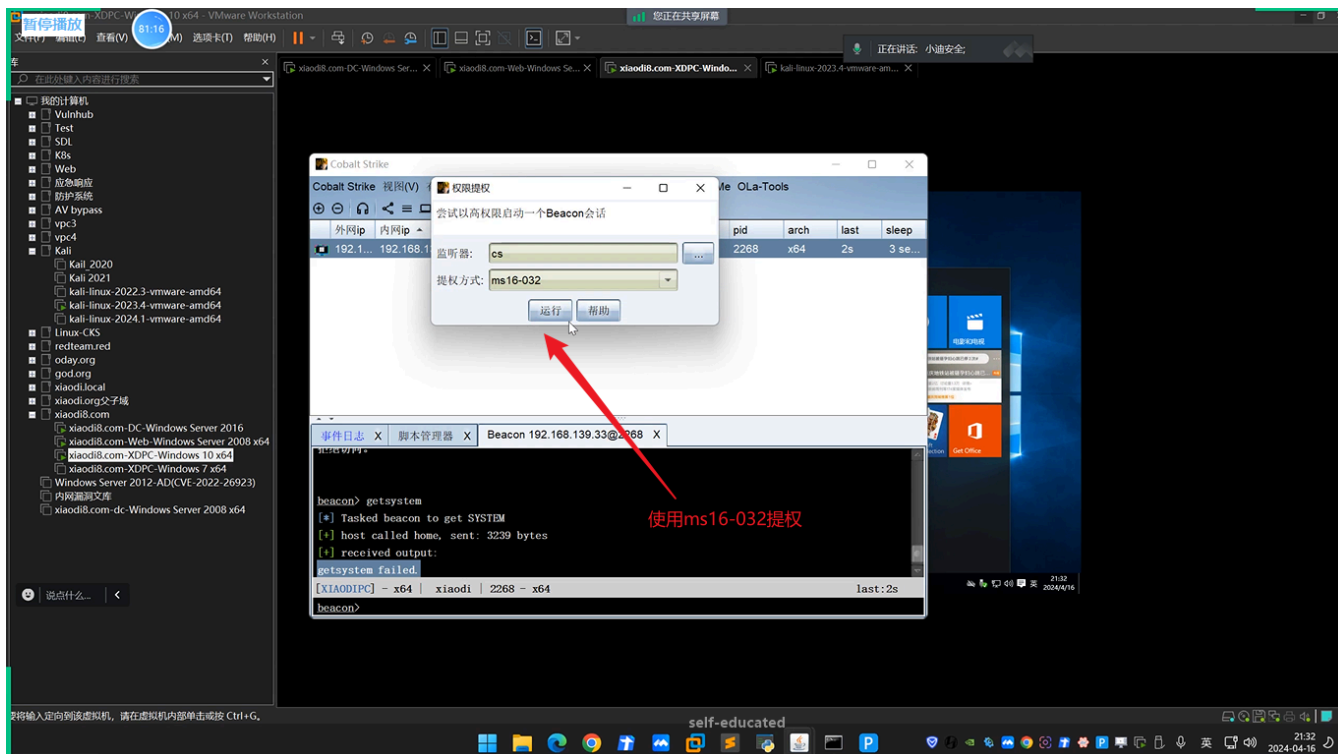
(2) 如何定位域控DC:



(3) 如何获取其他信息:







后续就可以使用mimikatz获取主机的账号密码，使用域内账号密码登录，探测域内主机DC，进行横向移动。